

504.2

Recon, Scanning, and Enumeration Attacks

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE ASSOCIATED WITH THE SANS COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE "USER") AND SANS INSTITUTE FOR THE COURSEWARE. YOU AGREE THAT THIS AGREEMENT IS ENFORCEABLE LIKE ANY WRITTEN NEGOTIATED AGREEMENT SIGNED BY YOU.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware includes all printed materials, including course books and lab workbooks, as well as any digital or other media, virtual machines, and/or data sets distributed by SANS Institute to User for use in the SANS class associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCEPTING THIS COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. BY ACCEPTING THIS SOFTWARE, USER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree, User may return the Courseware to SANS Institute for a full refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There's an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

All reference links are operational in the browser-based delivery of the electronic workbook.



Recon, Scanning, and Enumeration Attacks

© 2022 SANS Institute | All Rights Reserved | Version H02_07

Hello and welcome to section 2 of SEC504: Hacker Tools, Techniques, and Incident Handling.

Section 1 covered policy and procedures for incident handling. In this section, we discuss how attackers conduct common attacks, and how you can prepare your defenses to handle them, focusing on reconnaissance (recon), scanning, and enumeration attacks. Our exploration of cyber attacks and defenses encompass the rest of this course. Let's continue our journey!

Section 2 of SANS SEC504 is written by Joshua Wright, with support from Ed Skoudis and John Strand.

Table of Contents (I)

Page

Hacker Tools, Techniques, and Exploits Introduction

4

MITRE ATT&CK Framework

11

Open-Source Intelligence

16

Lab: OSINT with SpiderFoot

29

DNS Interrogation

30

Lab: DNS Interrogation

37

Website Reconnaissance

38

Network and Host Scanning with Nmap

48

Lab: Nmap

64

Cloud Spotlight: Cloud Scanning

65

Lab: Cloud Scanning

80

SMB Security

81

This table of contents can be used for future reference.

Table of Contents (2)

Page

Lab: SMB Security

96

Defense Spotlight: DeepBlueCLI

97

Lab: Windows Password Spray Attack Detection

106

This table of contents can be used for future reference.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

Hacker Tools, Techniques, and Exploits

Introduction

MITRE ATT&CK Framework

Open-Source Intelligence

Lab: OSINT with SpiderFoot

DNS Interrogation

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

...

We'll start this section with an introduction to the tools, techniques, and exploits content we'll be exploring for the rest of the course.

Purpose of This Course

- The purpose of this course segment is to understand attack methods ...
- ... so we can implement effective defense strategies
- Designed for incident handlers, security personnel, and system administrators
- What do the attacks look like, and how can we apply the incident handling process we discussed in 504.1?
 - How can we create effective defenses?
 - That's the reason we're here

This course is not designed to teach you how to hack. Still, to create an effective defense, we must understand the offensive tools attackers use. That's what this segment of the course is all about: Learning what the attackers do so we can defend ourselves. This course is designed for incident handlers, security personnel, and system administrators.

We cover attack concepts, which include scanning, gaining access, modifying systems, and hiding. We examine these topics because we can apply what we learn about attacker tools, techniques, and procedures (TTPs) to create better defenses against these attacks.

Also, note the difference that the underground community applies to the terms hacker and attacker. According to the hacker community, a *hacker* is a highly intelligent individual who wants to explore technology to learn. An *attacker* is someone who maliciously breaks into a system. Throughout the course, I refer to intruders as attackers, adversaries, or threat actors. Unfortunately, the major media does not see this distinction and often will label attackers as *hackers*.

Why We're Covering What We're Covering

- Why we chose these tools and techniques
 - They are in widespread use right now
 - They provide us fundamental information about the principles the attackers employ
 - They illustrate what we need to do to defend ourselves
 - Some of them are amazing, and terrible

Tools selected based on the collective experiences at the SANS Internet Storm Center, incident response activities in large and medium enterprises, and the MITRE ATT&CK Framework.

During this course, we will cover about 100 tools and techniques. We select these attacks because they are the most damaging and widely used today according to the attacks seen through the SANS Internet Storm Center and the MITRE ATT&CK framework. In addition, each attack illustrates what we need to do to defend our systems. Never underestimate your adversaries! You need to understand their tactics and be ready to defend your network.

Always Get Permission

- Full and documented permission is essential before you run any of these tools on a network
- When getting permission, it needs to be in writing
 - Verbal agreements don't hold up too well in court
- The documented permission should also state that the giver of permission understands there may be potentially *adverse* side effects of the scanning or testing activity
 - This is also known as a *Get Out of Jail Free* document

Sample permission form at https://www.counterhack.net/permission_memo.html

Testing is often done without proper permission. People may believe that if they are testing a *friend's* network or a network for a company they work for, they will be fine. However, we would caution anyone doing any testing to always get documented permission. A verbal agreement is never good enough.

Remember, if something goes wrong, people will try to find someone to blame. Unfortunately, it is very easy to target the person who ran the test.

Always get permission from the appropriate authorities in your company before using any computer attack tools to locate vulnerabilities. You can find a sample form for getting such permission at https://www.counterhack.net/permission_memo.html. Have your lawyers look it over and tweak it to fit your needs. Please note that this form is suitable for employees doing a test of their employer. It is NOT suitable for a third-party penetration testing company, as it does not include limitation of liability language required for such contractual relationships.

General Trends: Attack for Fun and ***PROFIT***

- Attackers are figuring out how to make money from their malicious code
- Ask law enforcement: If there's money in a given crime, we'll see much more of it
- How to make money on malicious code:
 - Cryptocurrency miners
 - Spam and web-based advertising
 - Phishing: Email, phone, and targeted (spear) phishing
 - Denial-of-Service extortion
 - Keystroke loggers stealing financial information
 - Rent out armies of infected systems for all the above
 - RAM scrapers pulling CC numbers from POS terminals
- Ransomware, ransomware, ransomware

One of the big infosec stories of recent times involves attackers learning to make money from their activities, ranging from exploiting browser vulnerabilities for grabbing financial data to utilizing access to deploy ransomware throughout large and small organizations. Indeed, we have seen attackers directly selling to the highest bidder customized malicious code to control victim machines or even renting out armies of infected systems useful for cryptocurrency mining, spam delivery, phishing schemes, Denial-of-Service attacks, or identity theft. As the attackers hone their business models, look for more of the attack types we've seen this year, but cranked up several notches.

Perhaps one of the most significant attack trends is the acute rise in ransomware, with many companies making the controversial decision to pay ransom to retrieve their data files. This technique has been a financial windfall for attackers and will continue unabated for many years to come.

General Trends: Consumer Device Attacks

- Internet of Things devices are widespread
 - In the home, and in the enterprise
- Price competition between vendors and short time-to-market development cycles often produces lackluster security features
- Product adoption continues with little ability to manage devices on a large scale



Using an initial attack vector against the AXIS M3004-V camera, attackers gain internal network access to exploit critical systems.

Industry experts expect 50B IoT devices by 2030.

Another trend is the continued deployment of Internet of Things (IoT) devices, both in the home and in enterprise networks. Unfortunately, many of these IoT devices have lackluster security, often the result of short time-to-market development cycles, and price competition between vendors that eliminates *costly* security development and evaluation/pen-test activities. Despite these issues, IoT device adoption is continuing to rise, with Statista forecasting that there will be 50 billion IoT devices by 2030 (<https://www.statista.com/statistics/802690/worldwide-connected-devices-by-access-technology/>).

One recent example is the attack against the AXIS M3004-V camera product. Though AXIS released a security update to address platform vulnerabilities, IoT products often go unpatched for extended periods of time. In an article covered by WIRED Magazine (<https://www.wired.com/story/elaborate-hack-shows-damage-iot-bugs-can-do/>), IoT security firm Senrio discusses the interesting points of attacking this IoT device, using initial access not only to view video and audio streams without access, but also to leverage the compromise as an initial point of access to attack other internal hosts.

General Trends: The Golden Age

- Attackers are growing in sophistication
- ... but so are defenders!
 - More scientific and precise approaches to defense
 - Costly breaches have produced top-level support for infosec
 - Increasingly effective analysis tools
- Demand is growing for IT professionals with infosec skills
 - Knowing systems and networking is good
 - *Adding infosec skills differentiates you from your peers*

Bottom line: It's a good time to be an attacker (or a security practitioner)

Most of the content in this module has looked at the ways in which attackers are growing in sophistication. Whether it is an attacker's tools, the techniques they employ, or their procedures including amazing breakout time, attackers and their techniques are on the rise.

Fortunately for us, so are the defenders! More than ever before, defenders are employing more scientific and precise approaches to defense with powerful frameworks and measured efficacy to truly understand if techniques are successful. What's more, costly breaches have produced top-level support for infosec in many organizations, producing funding and top-down support for security initiatives. Further, analysis tools for identifying threats (such as vulnerability scanners, network monitoring tools, security information and event management/SIEM) are becoming more impressive, allowing analysts to focus on identifying what is important to the organization.

A big part of this general trend is the growing demand for IT professionals with information security skills. There simply aren't enough people who understand IT skills such as systems and networking that also have strong infosec skills. Having infosec skills in addition to IT skills is a great way to differentiate you from your peers.

The bottom line here is that we live in the Golden Age of Hacking. But it's also the Golden Age of Information Security. The two go hand in hand.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

Hacker Tools, Techniques, and Exploits

Introduction

[MITRE ATT&CK Framework](#)

Open-Source Intelligence

Lab: OSINT with SpiderFoot

DNS Interrogation

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

...

Next, we'll introduce an important project that will guide our analysis of hacker tools, techniques, and exploits: The MITRE ATT&CK Framework.

MITRE ATT&CK Framework

- MITRE is a not-for-profit US company managing technical Federally Funded Research and Development Centers (FFRDCs)
- ATT&CK Framework is a knowledge base, mapping adversary tactics, techniques, and procedures (TTPs)
 - Based on real-world observations
- ATT&CK integrates a common nomenclature for attacks

Attacker TTPs are complex and difficult to characterize comprehensively. ATT&CK provides an easy framework to characterize and cross-reference attack techniques to gain better insight into how attackers operate, and how to defend networks.

In this course, we will often refer to the MITRE ATT&CK (Adversarial Tactics, Techniques and Common Knowledge) framework. MITRE is a not-for-profit US company that manages technical Federally Funded Research and Development Centers (FFRDCs). Essentially, MITRE is funded by the US government, and takes on several important projects, several of which are aimed at information security needs.

The MITRE ATT&CK Framework (ATT&CK) is a free knowledge base, mapping known adversary tactics, techniques, and procedures (TTPs) from real-world observations. ATT&CK aims to characterize the techniques of adversaries, from initial access to data exfiltration and organizational impact, identifying the adversary groups that have successfully implemented the techniques.

ATT&CK is also useful as a real-world example of consistent language and nomenclature for attacks. ATT&CK integrates a standard nomenclature for the terms and definitions to describe attacks in a clear and consistent manner.

Fundamentally, characterizing the TTPs of varied attacker groups is hard. The MITRE ATT&CK Framework provides an accessible breakdown of attack techniques and concepts that we can use to gain better insight into how attackers operate, and from that knowledge, how to better defend our networks.

The MITRE ATT&CK Framework project is available at <https://attack.mitre.org>.

Reconnaissance 10 techniques	Resource Development 7 techniques	Initial Access 9 techniques	Execution 12 techniques	Persistence 19 techniques	Privilege Escalation 13 techniques	Defense Evasion 42 techniques	Credential Access 16 techniques	Discovery 30 techniques
Active Scanning (3)	Acquire Infrastructure (6)	Drive-by Compromise	Command and Scripting Interpreter (8)	Account Manipulation (5)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Adversary-in-the-Middle (3)	Account Discovery (4)
Gather Victim Host Information (4)	Compromise Accounts (2)	Exploit Public-Facing Application	Container Administration Command	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery
Gather Victim Identity Information (3)	Compromise Infrastructure (6)	External Remote Services	Deploy Container	Boot or Logon Autostart Execution (14)	Access Token Manipulation (5)	Access Token Manipulation (5)	Credentials from Password Stores (5)	Browser Bookmark Discovery
Gather Victim Network Information (6)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery
Gather Victim Org Information (4)	Establish Accounts (2)	Phishing (3)	Inter-Process Communication (3)	Browser Extensions	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard
Phishing for Information (3)	Obtain Capabilities (6)	Replication Through Removable Media	Native API	Compromise Client Software Binary	Create or Modify System Process (4)	Deobfuscate/Decode Files or Information	Forge Web Credentials (2)	Cloud Service Discovery
Search Closed Sources (2)	Stage Capabilities (5)	Supply Chain Compromise (3)	Scheduled Task/Job (5)	Create Account (3)	Domain Policy Modification (2)	Deploy Container	Input Capture (4)	Cloud Storage Object Discovery
Search Open Technical Databases (5)		Trusted Relationship	Shared Modules	Create or Modify System Process (4)	Escape to Host	Direct Volume Access	Modify Authentication Process (5)	Container and Resource Discovery
Search Open Websites/Domains (2)		Valid Accounts (4)	Software Deployment Tools	Event Triggered Execution (15)	Event Triggered Execution (15)	Domain Policy Modification (2)	Multi-Factor Authentication Interception	Debugger Evasion
Search Victim-Owned Websites			System Services (2)	User Execution (3)	Exploitation for Privilege	Execution Guardrails (1)		Domain Trust Discovery
			User Execution (3)			Exploitation for Defense Evasion		File and Directory Discovery
						File and Directory Permissions		

In this course, we will focus primarily on two of the attacker TTP matrices outlined in the MITRE ATT&CK Framework: The *enterprise* matrix, and the *Pre-ATT&CK* matrix.

A screenshot of the partial enterprise attack matrix is shown on this page, outlining the attacker technique categories as column headings (starting with *initial access*, *execution*, *persistence*, etc.) The actual techniques themselves populate the columns (such as, for initial access, *drive-by compromises*, *exploitation of public-facing applications*, etc.) using sub-headings for similar techniques.

Clicking on any of the links in this matrix will give you more information about *how* an attacker mounts a drive-by compromise (for example), including the *who* (which threat groups use this tactic) and *what* tools an attacker uses to achieve the goal.

At first, the ATT&CK enterprise matrix can be overwhelming, but after spending a few minutes using it, you will likely realize the value this project offers to defenders. We can use ATT&CK to evaluate our own knowledge of attacker TTPs and evaluate how our organization would fare when faced with any of these attacks. We can gain threat intelligence insight about specific threat actors (attackers), characterizing the vertical industries that the attackers target in comparison to our own.

- Content is *normalized* using the nomenclature conventions adopted by ATT&CK
 - This gives you a consistent framework to work from when describing, documenting, and discussing attacker tactics, techniques, and procedures
- Cross-reference tools and techniques with ATT&CK identifiers
 - "*Let's talk about password spray attacks*" (Credential Access: TA0006)
 - "*Donut injects shellcode into existing assemblies and payloads*" (Process Injection: T1055)
- Validation for attack tool and defense realism

The MITRE ATT&CK framework creates a great opportunity to apply the skills you learn in class when you get back to the office.

Throughout the rest of the course, we will embrace the MITRE ATT&CK Framework as we look at attacker tactics, techniques, and exploits. We normalize the language and naming conventions adopted by ATT&CK to give you a consistent set of language and nomenclature for documenting, discussing, and characterizing attacker TTPs.

As we look at different attacker tactics, techniques, and exploits, we will cross-reference the topics with the ATT&CK identifiers. For example, when we cover password spray attacks, we will cite the subject matter as *Credential Access* (using the ATT&CK nomenclature) and the numeric identifier to make it easy to cross-reference our topic in class with the additional reference resources cited by MITRE.

All the attacker tactics, techniques, and exploits that we cover in SEC504 are also characterized by the ATT&CK framework. This should help reinforce the realism of the course material, since all the topics we look at are in use by attackers in networks very similar to yours, today.

MITRE ATT&CK References

MITRE ATT&CK

Password Cracking

T1110

- Fundamental technique for attackers
 - Exploit a system of low-to-medium importance
 - Dump all available password hashes
 - Crack password hashes for as long as necessary
 - Reuse recovered passwords to access high-importance targets
- We'll look at two tools: John the Ripper and Hashcat

Both John the Ripper and Hashcat offer useful features to the attacker and should be part of your bag of tricks for audit and vulnerability analysis

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling 31

In this module, we'll look at a fundamental technique for attackers: Password cracking. Consider the following scenario:

- Attacker compromises a system of low-to-medium importance. Possibly a Windows host, or an IoT device, or even a standalone server.
- Attacker uses their access to dump all the available hashes from the system.
- Attacker cracks password hashes for as long as needed to recover plaintext passwords.
- Attacker reuses recovered password values to access high-importance targets.

Attack techniques and tactics are categorized with a MITRE ATT&CK ID in the top right corner.

Notes pages provide reference links for techniques and tools.

Throughout the course when we introduce an attack technique, we will identify the *tactic ID* (beginning with *TA*), or a more specific *technique ID* (beginning with *T*), where appropriate for broad categorization (tactics) or specific categorization (techniques). These identifiers are noted in the top right-hand corner of the page (shown in the example on this page). Additional information, including specific technique IDs and references links, are included in the notes near the bottom of the page.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

...

MITRE ATT&CK Framework

[Open-Source Intelligence](#)

Lab: OSINT with SpiderFoot

DNS Interrogation

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

Lab: Cloud Scanning

...

The first step in most attacks is to gain as much information about the target as possible. With the wide variety of information sources available today, a great deal of useful data can be gathered.

Reconnaissance

- Reconnaissance is *building intel, looking for opportunities*
- Two general types of attackers
 - Non-discriminating attackers: Look for low-hanging fruit, and may skip this step (*musabetsu-kougeki*)
 - Attackers out to get a particular site: This step is extremely important
- Helpful step for experienced attackers
- Reconnaissance usually begins with OSINT collection

The internet is a treasure trove of information for a curious attacker.

Detailed reconnaissance helps an attacker get a feel for your network before ever firing a packet in anger. The internet itself is a treasure trove of information for a curious attacker.

To begin an attack, your adversaries gather as much information as possible from open sources. Think about attacks in the plain-old real world for a minute. (I know it's hard to think about non-virtual things ... but occasionally we must.) Before bandits rob a bank, they visit a branch, look at the times that the security guards enter and leave, and note the location of security cameras. In addition, they may even use the phone book to find the address of the bank and a map of the city to plan their getaway path. This is the same first step in cyber attacks. These bandits are out to rob a particular target and are taking their time to be more sophisticated in their analysis to increase their likeliness of success.

Returning to the modern world, we would classify attackers as being non-discriminating (in Japanese, *musabetsu-kougeki*) when they search for any target that matches an exploit or attack technique they know. Sometimes they are referred to as *script kiddies*, but in general they just aren't picky: They will exploit anything that matches their combination of vulnerable target and known attack technique. These non-discriminating attackers will often skip the reconnaissance phase of analysis, much to their detriment.

By contrast, there are also attackers that are solely dedicated to attacking a particular site. When their goal is to compromise a single target organization, before they send the first packet, they conduct detailed reconnaissance analysis to collect as much information about the target that they can find to aid in their attack. The available data that an attacker collects is known as Open-Source Intelligence or *OSINT*.

The many steps involved with reconnaissance analysis is described in the MITRE PRE-ATT&CK Matrix (<https://attack.mitre.org/matrices/pre/>). We'll examine several of the steps described in the PRE-ATT&CK matrix in this module.

Open-Source Intelligence

Before sending your first packet to a target, you should collect OSINT data

- All organizations have lots of data online
 - *Planned sharing*: Annual reports, contact information, website content, press releases, etc.
 - *Unplanned sharing*: Hacked email addresses for third-party websites, employee social media content, website certificate details, internal server links, public forum data, document metadata, ... and many more!
- OSINT is the collective representation of this data in a useful manner
- Leveraged offensively and defensively

OSINT is an exciting area for attack and defense with an active development community!

Before sending the first packet to a target, a modern attacker will harvest *open-source intelligence* (OSINT) information. OSINT is the cumulative data known about a target online, whether that is a target organization, a target person, or other candidate.

All organizations share data online. Generally, this sharing falls into two categories:

Planned Sharing: Organizations share information online such as annual reports, contact information, website information, press releases, etc.

Unplanned Sharing: Organizations also share a tremendous amount of *unplanned* information online. In some cases, this is leaked information not recognized as leaked by the organization (such as employee social media use, public discussion forum information, and content from third-party websites or partner organizations), and sometimes it is the publication of leaked data obtained illegally (such as compromised passwords, stolen documents, internal server configuration details, etc.)

OSINT is the collective representation of this data in a useful manner, giving an attacker insight into critical information before starting their attack. This can be the identification of server hostnames, email addresses, usernames, and network configuration settings, but it can also be more technical, detailed information such as the exact version of Microsoft Word used by the CEOs administrative assistant that is vulnerable to a command execution vulnerability.

OSINT data sources and tools are an exciting area of information security, with a lot of active development in both free and commercial tools. OSINT is not just an attack technique — it is used both offensively, and defensively, as we'll see in this module.

The process of collecting OSINT information is classified as *Acquire OSINT data sets and information* in the MITRE PRE-ATT&CK framework as ID T1266 (<https://attack.mitre.org/techniques/T1266/>).


```
$ whois hasborg.com
```

```
Domain Name: HASBORG.COM
```

```
Registrar WHOIS Server: whois.godaddy.com
```

```
Registrar URL: http://www.godaddy.com
```

```
Updated Date: 2014-10-26T19:08:56Z
```

```
Creation Date: 2004-01-26T20:49:19Z
```

```
Registrar Registration Expiration Date: 2020-01-26T20:49:19Z
```

```
Registrar: GoDaddy.com, LLC
```

```
Registrar Abuse Contact Email: abuse@godaddy.com
```

```
Registrar Abuse Contact Phone: +1.4806242505
```

```
Domain Status: clientTransferProhibited
```

```
http://www.icann.org/epp#clientTransferProhibited
```

```
Registrant Organization: Hasborg, Inc.
```

```
Registrant State/Province: Rhode Island
```

```
Registrant Country: US
```

```
Registrant Email: Select Contact Domain Holder link at
```

```
https://www.godaddy.com/whois/results.aspx?id=J7TA5oEZ8R8JbAAAdtaCg
```

```
Name Server: NS1.DIGITALOCEAN.COM
```

```
Name Server: NS2.DIGITALOCEAN.COM
```

WHOIS data used
to be a valuable
source of email,
phone, and address
data. GDPR
compliance ended
that run.

One classic source of OSINT information is the collection of WHOIS data. When a registrar registers a domain name, they collect information about the registrant including name, phone number, address, and email information. This contact information can differ for the billing, technical, and administrative contacts for the domain. Multiple online services are available to collect WHOIS information, but there is also a built-in Linux tool `whois`, as shown on this page.

WHOIS information stopped being quite as useful in 2016 with the introduction of the European requirements for *General Data Protection Regulation* (GDPR). On May 25, 2018, the mandatory compliance date for GDPR, most of the public information listed in WHOIS records became inaccessible. Some information is still available, such as the domain registrant organization, state, and country information (shown on this page for the author's domain).

WHOIS data is classified as by the MITRE PRE-ATT&CK Framework, ID T1596.002 (<https://attack.mitre.org/techniques/T1596/002/>).

Certificate Transparency: The New WHOIS

OSINT

- Modern browsers do well detecting malicious website certificates
- Modern browsers do *not* do well detecting malicious certs issued by trusted CAs
- Cert transparency requires CAs to publish certificate issuance logs
 - Open to scrutiny to look for suspicious certs ... and for OSINT gathering
- Gather information about targets, which CAs are in use, when certs are renewed, and more!

TIP

Use certificate transparency searches to identify unknown targets associated with an organization, or the presence of new hosts that have not yet been advertised as available.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

20

Although WHOIS data is no longer readily available, there is another source of valuable OSINT data that is freely available through *certificate transparency*.

Modern web browsers do well at detecting malicious websites. Using SSL/TLS certificates and HTTP *Strict Transport Security* features on web servers, browsers can identify an imposter site that impersonates a legitimate site well. What modern browsers do not do well is to identify the presence of a malicious certificate issued by a trusted certificate authority (CA).

Certificate transparency is a CA requirement where they must publish logs of all issued certificates. The logging data makes certificate issuance details subject to scrutiny and auditing, so other CAs can identify if there is suspicious activity.

For attackers, certificate transparency is useful to reveal information about the nature of certificates used at an organization, including the hostname (or *common name*) information included in the certificate. Often this is useful for identifying the presence of systems that are not yet publicly available (or widely known to be publicly available) as additional attack targets.

The screenshot shows the 'haveibeenpwned.com' website. The main heading is ';--have i been pwned?'. Below it, a search bar contains the email 'jwright@hasborg.com'. The result is 'Oh no — pwned!' with a subtext 'Pwned on 11 breached sites and found no pastes (subscribe to search sensitive breaches)'. A grey box contains the text: 'Identify if an account has been breached, then collect site passwords to explore password reuse exposure.' On the right, a list of breaches is shown, including 'Anti Public Combo List', 'APOLLO', and 'bitly', each with a brief description and a list of compromised data.

Anti Public Combo List (unverified): In December 2016, a huge list of email address and password pairs appeared in a "combo list" referred to as "Anti Public". The list contained 458 million unique email addresses, many with multiple different passwords hacked from various online systems. The list was broadly circulated and used for "credential stuffing", that is attackers employ it in an attempt to identify other online systems where the account owner had reused their password. For detailed background on this incident, read Password reuse, credential stuffing and another billion records in Have I been pwned.
Compromised data: Email addresses, Passwords

APOLLO Apollo: In July 2018, the sales engagement startup Apollo left a database containing billions of data points publicly exposed without a password. The data was discovered by security researcher Vinny Troia who subsequently sent a subset of the data containing 126 million unique email addresses to Have I Been Pwned. The data left exposed by Apollo was used in their "revenue acceleration platform" and included personal information such as names and email addresses as well as professional information including places of employment, the roles people hold and where they're located. Apollo stressed that the exposed data did not include sensitive information such as passwords, social security numbers or financial data. The Apollo website has a contact form for those looking to get in touch with the organisation.
Compromised data: Email addresses, Employers, Geographic locations, Job titles, Names, Phone numbers, Salutations, Social media profiles

bitly Bitly: In May 2014, the link management company Bitly announced they'd suffered a data breach. The breach contained over 9.3 million unique email addresses, usernames and hashed passwords, most using SHA1 with a small number using bcrypt.
Compromised data: Email addresses, Passwords, Usernames

SANS SEC504 | Hacker Tools, Techniques, and Incident Handling 22

Another useful OSINT resource is the haveibeenpwned.com website, run by Troy Hunt. Have I Been Pwned collects lists of usernames and passwords from major website breaches and provides a search service to determine if an email address or username is known to have been included in a major breach.

While the Have I Been Pwned website does not share the password information associated with a compromised account, it does list the breaches that are associated with the account information. In the example on this page, my username and password has been compromised from multiple breaches (as shown on the right of this page). As an attacker, this is useful information, since it is sometimes possible to collect the usernames and passwords associated with the known breaches. Knowing the password used by the victim of a breach can be an easy way into a target network, simply through password reuse exposure.

The Have I Been Pwned website also offers programmatic API services, making it possible to conduct account compromise searches for lists of users.

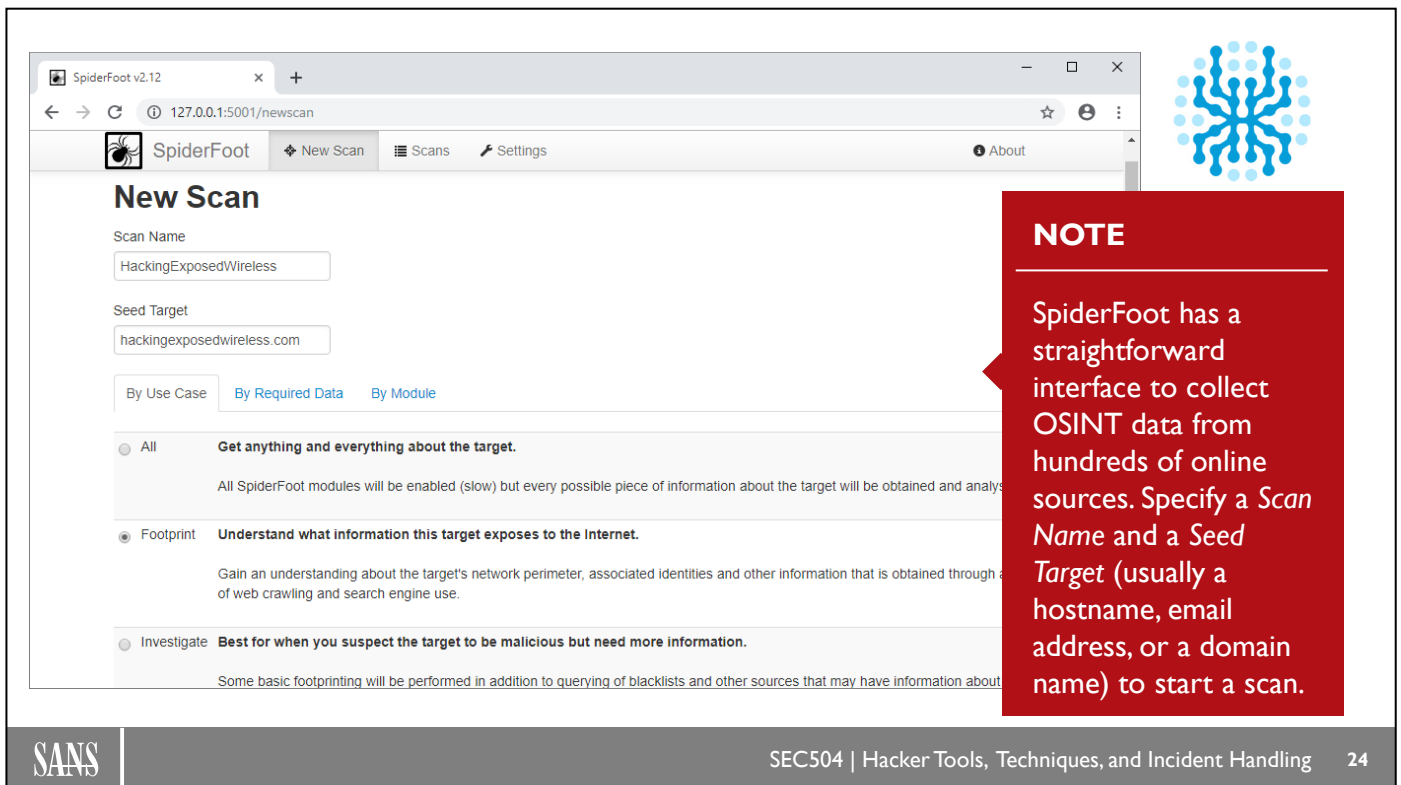
The challenge of OSINT data: *lots of unique data sources*

- OSINT data sources are many and varied in accessibility
 - Free, no registration required
 - Free, registration required
 - Paid, price per lookup
 - Paid, (insert payment collection model here)
- Accessibility and confidence in OSINT data sources can also be a challenge
 - Are you collecting all the information available?
 - How can you collect and parse the information quickly?

The primary problem with OSINT data collection is the many unique data sources, each providing unique data from varied search criteria. Many OSINT data services are free, but some require registration. Other OSINT data services require payment, sometimes charged as a price per search, a subscription model, a one-time cost, and many other variations.

The accessibility and confidence in OSINT data sources can also be a challenge. Are you collecting all the useful OSINT data that is available? How can you collect and parse the information that is available in a quick and cost-effective manner?

Fortunately, we have OSINT data aggregator tools that consume OSINT information from multiple sources, providing a single interface to store and process the collected information.

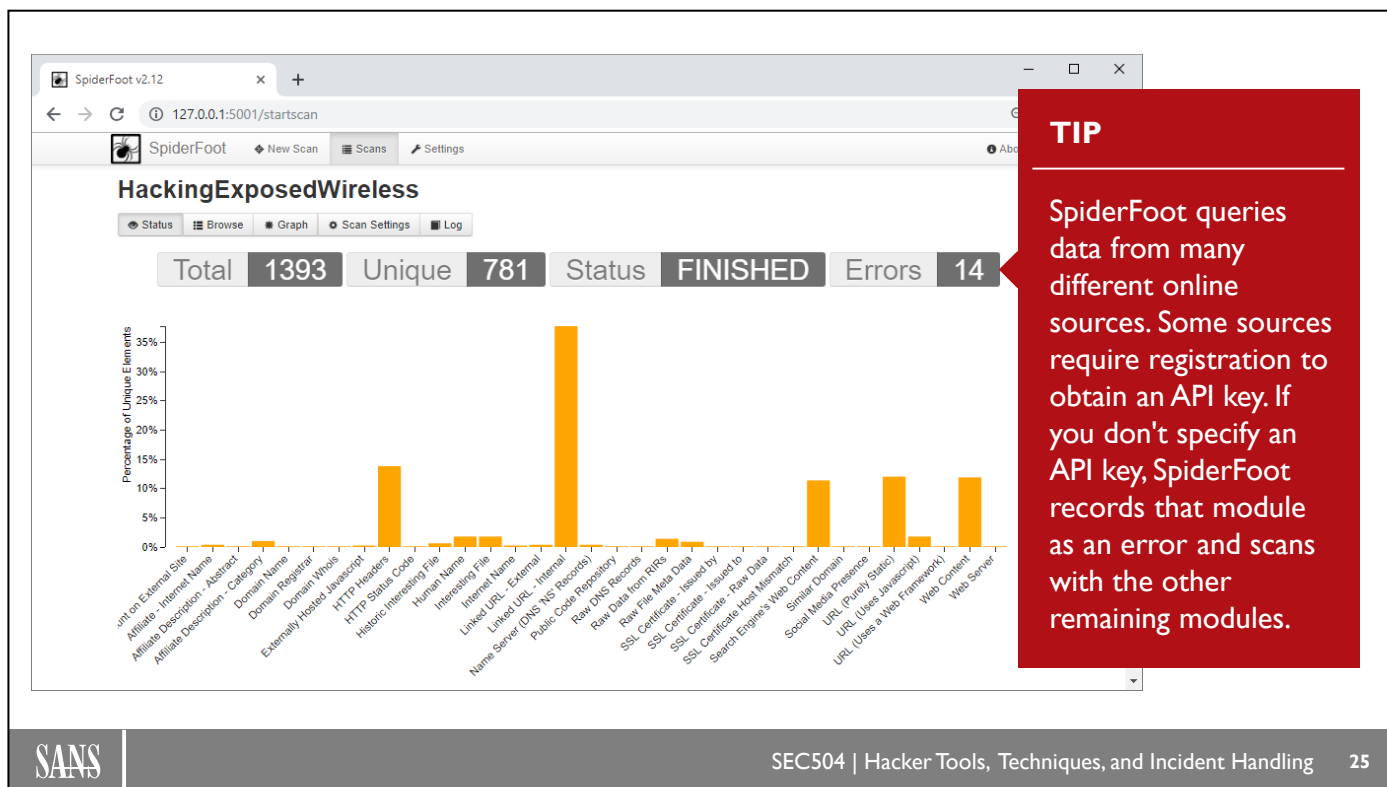


NOTE

SpiderFoot has a straightforward interface to collect OSINT data from hundreds of online sources. Specify a *Scan Name* and a *Seed Target* (usually a hostname, email address, or a domain name) to start a scan.

SpiderFoot is an open-source, GPL-licensed OSINT data collection and analysis tool created by Steve Micallef. With support for Linux, macOS, and Windows systems, SpiderFoot is straightforward to use and relatively fast. By providing a *seed target* (such as a domain name, a host name, or an email address), SpiderFoot collects OSINT data from hundreds of online sources, using the collected data to seed additional searches.

SpiderFoot is available at <https://spiderfoot.net>. The commercial companion tool, SpiderFoot HX offers many more features compared to the open-source version; more information is available at <https://www.spiderfoot.net/open-source-vs-hx>.



The SpiderFoot example on this page shows one of three completed scan result views. Here we see the *Status* view, which discloses the number of unique events (or pieces of information) disclosed for multiple OSINT sources or *modules* (listed across the bottom of the page). Clicking on any of these modules provides the detailed information supplied from the data source, formatted in a consistent view.

SpiderFoot also supports a graphical view of the collected data (not shown here). The graphical view shows the interconnected relationships between the data reported in SpiderFoot. For example, starting a search from a domain name may reveal a hostname, a web server, a webpage, and linked JavaScript content to a secondary domain. The SpiderFoot Graph view shows this relationship, making it possible to trace back the source of a given piece of collected information.

SpiderFoot supports the use of free OSINT data sources, though several sources require prior registration and configuration in SpiderFoot to supply an API key or other username and password. These options are available in the Settings window. If you do not supply a valid API key for these services, SpiderFoot records the source as an *error*, but continues to use the other available data sources to complete the scan.

Type	Unique Data Elements	Total Data Elements	Last Data Element
Account on External Site	1	1	2019-02-21 19
Affiliate - Internet Name	3	3	2019-02-21 19
Affiliate Description - Abstract	1	1	2019-02-21 19
Affiliate Description - Category	8	8	2019-02-21 19
Domain Name	1	1	2019-02-21 19
Domain Registrar	1	1	2019-02-21 19
Domain Whois	1	1	2019-02-21
Externally Hosted Javascript	2	28	2019-02-21 20
HTTP Headers	108	108	2019-02-21 20

TIP

View the SpiderFoot scan results as a chart, a graph, or a list view (shown here). Each module can be selected to look at the individual results, such as domain information, externally hosted resources, third-party affiliate relationships, file metadata, and more.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling 26

The example on this page from SpiderFoot shows a small excerpt from the scan results for one of this author's domains, hackingexposedwireless.com. SpiderFoot's modules revealed a single account on an external site that uses the target site domain name, multiple affiliate/partner data sources, and externally hosted JavaScript content. Not shown on this page are additional OSINT data sources, including file metadata, web server configuration settings, certificate transparency records, and more.

Not OSINT Data

OSINT

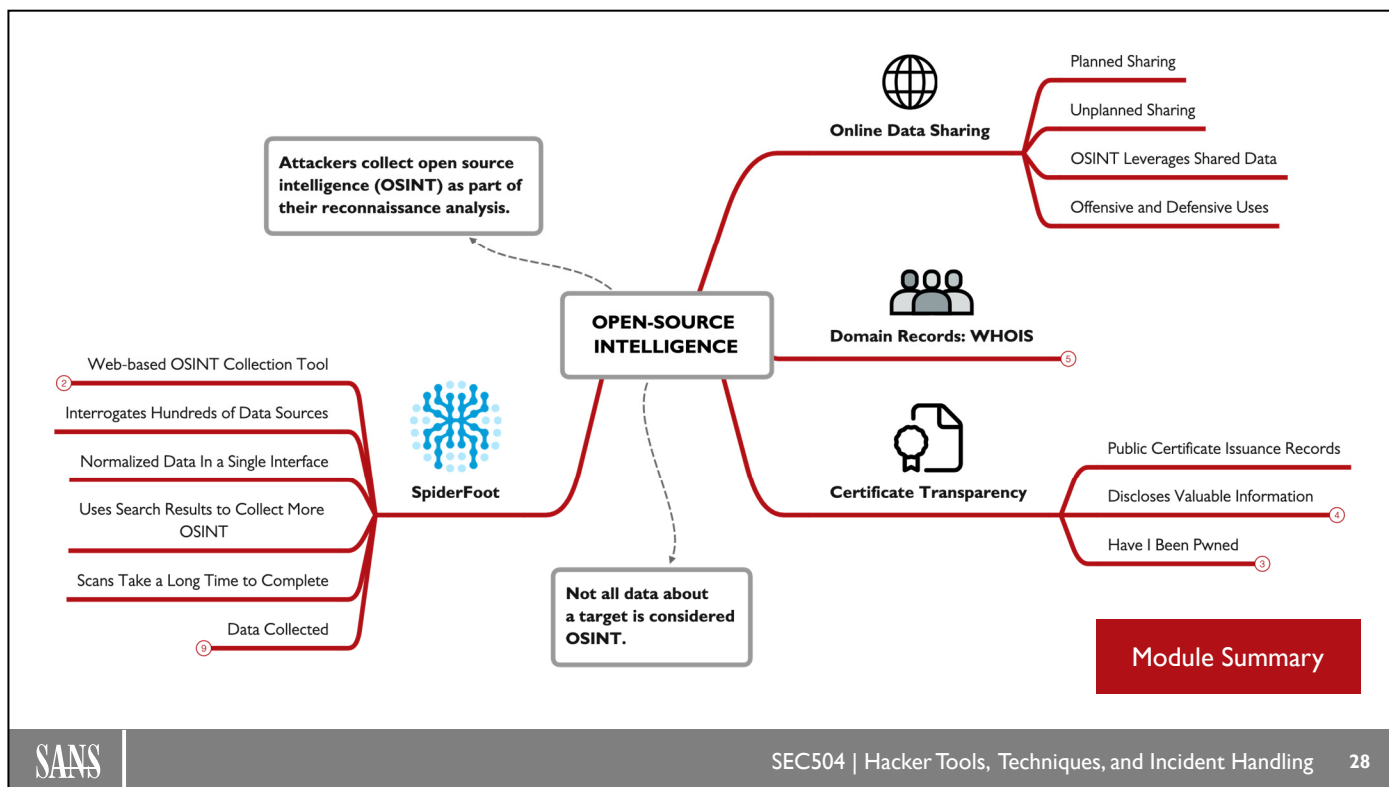
Where does OSINT Stop?

- Generally, OSINT data is collected from websites and APIs, through third-party collection sources
 - Great for attackers since it does not generate logs at the target site
- While abundant, OSINT is not the end of all available target data

Although some OSINT tools cross this line, any activity sent to the target site directly becomes *direct* reconnaissance. Next, we'll look at tools that provide additional information at the cost of potential target identification.

When collecting information for reconnaissance analysis, it is important to consider where OSINT data stops, and active scanning against a target begins. Generally, OSINT data is collected from public websites and third-party API services. This is beneficial to the attacker, since the information collected does not reach the target system directly, preventing any opportunity of discovery through log monitoring at the target organization. Tools that send requests directly to the target organization are no longer strictly OSINT, but rather a form of *direct* reconnaissance.

While abundant, OSINT data is not the end of all the available data that will assist in providing reconnaissance analysis of the organization. We'll also look at the use of additional tools to collect information, crossing the line from OSINT to direct reconnaissance analysis.



This visual association summary is included in your ISO media files as Summary-OSINT.pdf

In this module we investigated the topics surrounding how an attacker might use open-source intelligence (OSINT) resources as part of the reconnaissance or information-collection phase of an attack. We examined the many ways OSINT information can be disclosed through both planned and unplanned data sharing by employees. Attackers can use this disclosed information to gain insight into a target to precede an attack, and we can use it as defenders to better understand the risk of OSINT and how it could influence an attacker.

We looked at several examples of OSINT data including the use of internet domain name records disclosed through the WHOIS service. While WHOIS records were at one time a detailed source of information disclosing name, mailing address, phone number, and email address information a domain, the introduction of General Data Protection Regulation (GDPR) policies has changed the nature of this data. WHOIS records still represent a useful source of information, though limited to domain registrar and DNS server information.

Certificate transparency services are another OSINT data source that is valuable for an attacker. To protect against unauthorized certificate issuance from a compromised CA, all CAs trusted by major browsers must publish certificate issuance records that describe the companies and host names of issued certificates. Attackers and defenders can use public search services including crt.sh to search for certificate information, often disclosing host name and certificate authority selection for target organizations.

We looked at the challenges associated with OSINT use as well, including the complexity of multiple, unique data sources to collect OSINT data. SpiderFoot is a free and open-source tool for automating the collection of OSINT data from hundreds of data sources. SpiderFoot takes a search *seed* of information and interrogates multiple public and private OSINT data sources for information. This information is then reused to conduct additional searches, gathering valuable data about a target organization.

LAB

Please work on the lab exercise
OSINT with SpiderFoot



Please work on the lab exercise *OSINT with SpiderFoot*. For this lab exercise you will need your class Windows VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

...

Lab: OSINT with SpiderFoot

[DNS Interrogation](#)

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

Lab: Cloud Scanning

SMB Security

Lab: SMB Security

...

The attacker now has some useful information about the target. The last element obtained by the attacker included DNS server IP addresses for the target. The attacker can now try to harvest information from these DNS servers.

DNS Interrogation

- The Domain Name System is full of useful information about a target
- The attacker's goal is to discover as many IP addresses associated with the target domain as possible
- The `nslookup` command can be used to interact with a DNS server to get this data
 - Included in modern versions of Windows
 - Included in most UNIX implementations (deprecated in some UNIXes and limited on some Linux variants)
- Dig is another useful tool for DNS recon

Domain Name System (DNS) information is a valuable source of reconnaissance data for an attacker. An attacker can use DNS services to collect detailed information about your organization, including IP addresses, host names, email addresses, Mail eXchange (MX) records, and more.

The two primary tools to interrogate DNS servers are `nslookup` and `Dig`. `Nslookup` is available by default on Windows systems and is also available on some UNIX platforms. `Dig` is arguably a more powerful tool since you can control the output of DNS queries with more granularity than you can with `nslookup`. Both tools can be used effectively by an attacker.

DNS Zone Transfer in Windows

DNS Interrogation

- By dumping records from your DNS servers, attackers can determine which systems are accessible on the internet
- On Windows, collect DNS records using `nslookup`

```
C:\Users\Sec504> nslookup
> server 81.4.108.41
> set type=AXFR
> ls -d zonetransfer.me
zonetransfer.me.      A      5.196.105.14
zonetransfer.me.      NS     nsztml.digi.ninja
zonetransfer.me.      NS     nsztml2.digi.ninja
canberra-office       A      202.14.81.230
dc-office              A      143.228.181.132
```

A zone transfer allows an attacker to connect to your DNS server and grab all records associated with a particular domain. Essentially, zone transfers let an attacker grab a dump of your DNS server's brain.

By dumping all records from your DNS servers using zone transfers, an attacker can determine which systems are accessible on the internet. Using the UNIX `nslookup` command, a great deal of information can be gathered.

On Windows, simply type the following commands to perform a zone transfer:

```
C:\> nslookup
> server dnsserver
> set type=AXFR
> ls -d targetdomain
```

The `set type=AXFR` directive means that we want any type of DNS record, including Address (A) records, Mail eXchanger (MX) records, Host Info (HINFO) records, and nameserver (NS) records. Remember to run these commands against the primary, secondary, and any other domain name servers associated with the target organization.

The example zone transfer-vulnerable server at 81.4.108.41 is supplied by Robin Wood for the ZoneTransfer.me project. More information is available at <https://digi.ninja/projects/zonetransferme.php>.

The output shown in the example on this page has been modified for space.

DNS Zone Transfer in UNIX

DNS Interrogation

- On some UNIX variations, `nslookup` can be used for zone transfers
 - Using the same technique used for Windows on previous slide
- Other `nslookup` variations (including the one for recent versions of Linux) do not support zone transfer
- Use `dig` instead

```
$ dig @81.4.108.41 AXFR zonetransfer.me
zonetransfer.me.      7200    IN      A       5.196.105.14
zonetransfer.me.      7200    IN      NS      nsztml.digi.ninja.
zonetransfer.me.      7200    IN      NS      nsztml2.digi.ninja.
asfdbbox.zonetransfer.me. 7200    IN      A       127.0.0.1
```

On some versions of UNIX, you can use `nslookup` with the same syntax as Windows to do a zone transfer, just like we saw on the previous slide.

However, on recent versions of Linux, `nslookup` cannot do a zone transfer. Instead, we can use `dig` to achieve the same goal. To run a zone transfer using `dig`, type the following at the command prompt:

```
$ dig @dnsserver targetdomain AXFR
```

Replace *dnsserver* with the server IP address or hostname for the target DNS server.

DNS Automated Interrogation

DNS Interrogation

```
$ dig AXFR holidayhackchallenge.com
; Transfer failed.
$ sudo nmap --script dns-brute --script-args dns-brute.domain=holidayhackchallenge.com,dns-brute.threads=6,dns-brute.hostlist=./namelist.txt -sS -p 53
Starting Nmap 7.70 ( https://nmap.org ) at 2021-02-23 19:19 EST
| dns-brute:
|   DNS Brute-force hostnames:
|     qa.holidayhackchallenge.com - 35.196.52.224
|     docker2017.holidayhackchallenge.com - 35.190.163.207
|     download.holidayhackchallenge.com - 45.79.14.68
|     chat.holidayhackchallenge.com - 35.196.73.180
|     echo.holidayhackchallenge.com - 35.227.222.148
|_    www.holidayhackchallenge.com - 45.79.141.162
```

Many DNS servers will not permit the use of DNS zone transfers. However, DNS *automated interrogation* can still be a useful mechanism for host discovery. DNS active interrogation leverages a list of common hostnames (or a mutated list of hostnames, such as a common hostname followed by a series of numbers) and a target domain name to determine if the DNS name is present on the DNS server.

In the example on this page, we start by trying to complete a zone transfer for the holidayhackchallenge.com domain. The dig utility returns an error, indicating that the transfer has failed, indicating that the administrator has properly configured the DNS server. Next, we use the Nmap tool with the dns-brute script to actively interrogate DNS records for the holidayhackchallenge.com domain.

Note: We're going to cover the Nmap tool as a scanner in more depth later in this section. For now, we're just using Nmap for the dns-brute module functionality.

When using an Nmap script, arguments for the script follow the --script-args argument in a comma-separated list. In this example, we specify the target domain name following dns-brute.domain, specify the number of concurrent DNS queries to make at the same time with dns-brute.threads, and specify a word list of hostnames to use for active interrogation with dns-brute.hostlist. The remaining arguments -sS -p 53 are minimally needed for Nmap to perform the DNS brute force scan.

When the scan completes, we see that Nmap has identified several hostnames. These are all valuable targets for the attacker to know about, revealing functionality information for each.

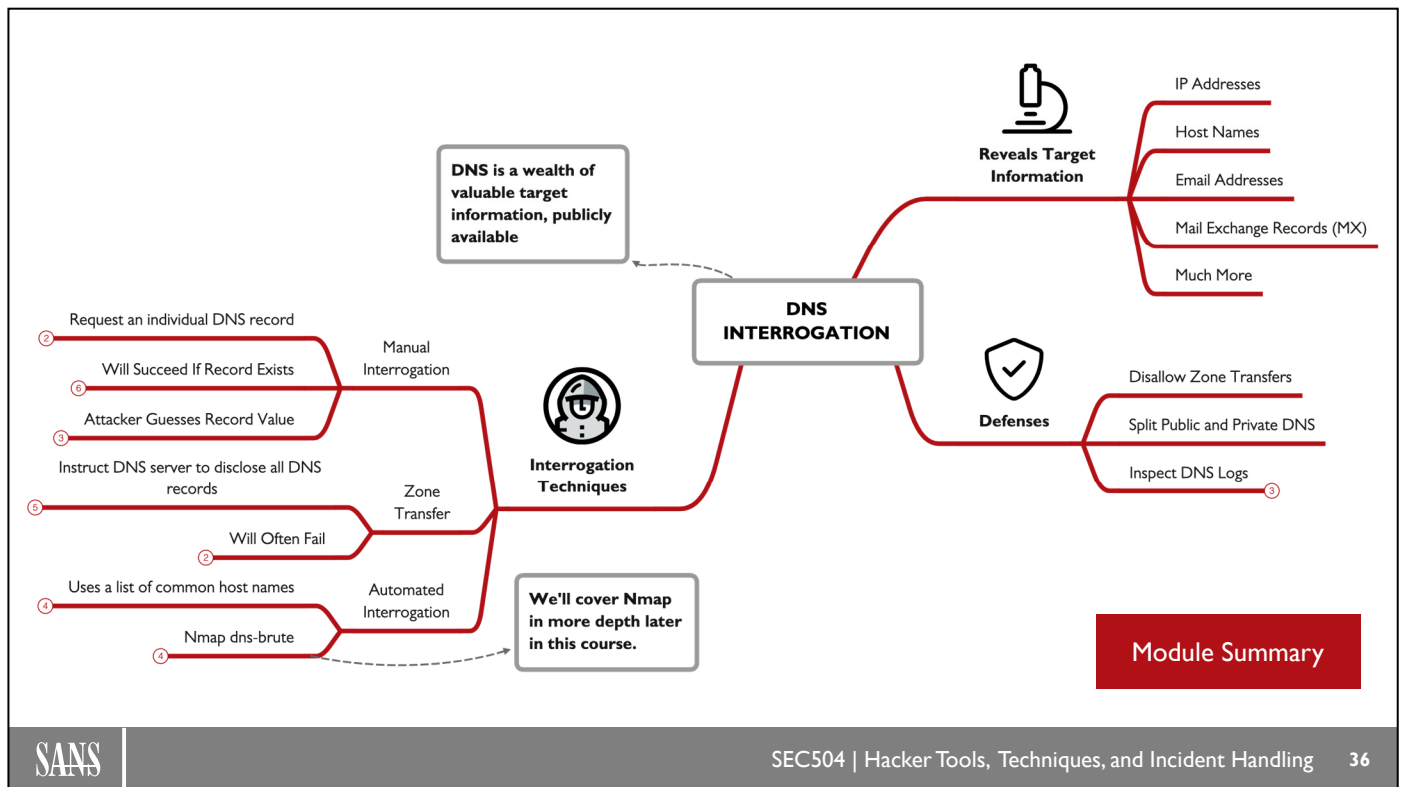
Tip: To be effective, Nmap's dns-brute module needs a list of hostnames (specified here as namelist.txt). If you do not specify this argument, Nmap's dns-brute script will use a built-in list of about 70 hostnames in ./share/nmap/nselib/data/dns-srv-names. Another source of hostnames is available through Daniel Miessler's SecLists project at <https://github.com/danielmiessler/SecLists/tree/master/Discovery/DNS>.

- Do not allow zone transfers from just any system
 - Limit zone transfer accessibility to DNS servers only
 - Secondary and tertiary servers should not accept zone transfers
- Use split DNS
 - External name information in external server, internal name information in internal servers
- Inspect DNS server logs for signs of attack
 - Look for zone transfers; failed and successful
 - Look for large numbers of requests from a single source (DNS brute)
 - Use attacking IP addresses to inform threat intelligence efforts

To defend against DNS-style reconnaissance, make sure you limit zone transfers. Your primary DNS server should allow zone transfers access by your secondary and tertiary DNS servers only. These servers, in turn, should be configured to deny all zone transfer requests. In addition, use split DNS. With such an implementation, you have two parts of your DNS infrastructure: External DNS servers and internal DNS servers. Publicly available DNS information is loaded on your external DNS servers. Internal names are only accessible from within your network. This configuration will prevent an attacker on the internet from accessing internal DNS names for assets within your organization, and it stops the attacker from implementing other DNS attacks such as cache poisoning attacks that can be used to attack internal network clients.

Finally, use DNS sever logging information to identify signs of attack. The logging information will change depending on your chosen DNS server software (ISC publishes BIND DNS software logging recommendation at <https://kb.isc.org/docs/aa-01526>; Windows server DNS logging documentation has not been updated since Windows Server 2012 R2, but it still applies to modern Windows Server deployments, <https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn800669%28v%3Dws%2E11%29> or <https://urls.sec504.org/as2bo>). It is easy to confuse legitimate DNS activity as a potential attack, so be cautious about taking action against a source IP address that appears to be attacking the DNS system.

Use the attacking IP address information revealed in logging data to inform your threat intelligence efforts. Considering adding the offending IP addresses to a *watch list* to see if there is additional activity to conclusively identify attack activity.



This visual association summary is included in your ISO media files as Summary-DNSInterrogation.pdf

In this module we investigated the topics surrounding DNS interrogation. DNS is a wealth of valuable target information, and most organizations will have at least some DNS information publicly accessible. DNS interrogation can reveal information about a target organization including IP addresses, host names, email address, Mail Exchange (MX) records, and more.

We focused on three different DNS interrogation techniques: manual interrogation, zone transfer, and automated interrogation. Manual interrogation uses a tool such as nslookup or dig to interrogate the DNS server for a specific record and record type. Manual interrogation can reveal some record types such as MX records by knowing just the domain name; other DNS records such as A or TXT records requires the attacker to guess a host name to retrieve the associated DNS information.

By contrast, a zone transfer attack is when an attacker requests the entire DNS database for a given domain name from the DNS server. Zone transfer attacks seldom work for public DNS servers but can be a significant source of data if disclosed through DNS misconfiguration.

Finally, we looked at the application of automated interrogation, where an attacker discovers DNS records similar to the manual interrogation technique, but with the help of automation. Using Nmap and the dns-brute attack script, an attacker can build a list of hostname and interrogate the DNS server for all names with a specified domain name, retrieving matching record information from the DNS server quickly.

LAB

Please work on the lab exercise
DNS Interrogation



Please work on the lab exercise *DNS Interrogation*. For this lab exercise you will need your class Slingshot Linux VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

...

DNS Interrogation

Lab: DNS Interrogation

[Website Reconnaissance](#)

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

Lab: Cloud Scanning

SMB Security

Lab: SMB Security

Defense Spotlight: DeepBlueCLI

Lab: Windows Password Spray Attack Detection

After getting information from whois databases and DNS servers, attackers also collect information from a widely accessible source: Public websites.

- Search the target's own websites:
 - Press releases
 - Technical papers
 - Design documents
 - Sample deliverables
 - Open positions
 - Key people
 - Contacts
- Search related sites
 - Business partners, suppliers, subsidiaries

TIP

Don't underestimate the value of information collected by simply browsing the target website. Username information, identities, positions within the organization, even conventions for how users log in to a server are valuable.

Corporate websites often contain contact information with phone numbers, which are useful for social engineering. Some sites even include a description of their computing platforms and/or architecture. Attackers grab a copy of your entire website to look for juicy tidbits about your organization.

Search engines are also useful. By searching for information about a target, an attacker can often learn about their platforms and architecture through UseNet postings of employees. Also, websites can indicate business partners and other potential links useful in spoofing and other attacks. Modern search engines (such as Google and Bing) include the ability to search for sites linking to the target. Simply search `link:www.[target_company].com` for all sites that link to the target.

Website reconnaissance is classified as *Technical Information Gathering* by the MITRE PRE-ATT&CK Framework, ID TA0015 (<https://attack.mitre.org/tactics/TA0015/>).

```
$ wget -q https://www.██████████.com/wp-  
content/uploads/2019/06/MEP_programsandprojects.pdf  
~ $ exiftool MEP_programsandprojects.pdf  
ExifTool Version Number      : 10.80  
Create Date                  : 2019:06:22 10:57:01-04:00  
Creator Tool                 : Acrobat Pro DC 19.10.20099  
Modify Date                  : 2019:06:22 10:57:06-04:00  
Metadata Date               : 2019:06:22 10:57:06-04:00  
Format                      : application/pdf  
Title                       : 20190622_11AM-long-deck_WEB  
Producer                    : macOS Version 10.14.5 (Build 18F203)  
Quartz PDFContext           :  
Schemas Property Value Type : Text  
Page Count                  : 96  
Creator                     : Acrobat Pro DC 19.10.20099
```

Exiftool is a Perl script that extracts metadata from many different file types including Microsoft Office, PDF, many different image file types, and more. Exiftool is available at <https://exiftool.org/> and is written by Phil Harvey.

In the example on this page, we used the `wget` utility to retrieve a PDF from a popular website (the website name has been redacted). Next, running `exiftool` followed by the filename will display all the available metadata associated with the file. Note that the output shown on this page has been modified for space.

In this output, we see that the PDF publisher used a macOS 10.14.5 system with Acrobat Pro DC 19.10.20099 to create the PDF. This is macOS Mojave, vulnerable to several issues fixed in later versions of macOS, including CVE-2019-8697 and CVE-2019-8695, allowing an attacker to execute arbitrary code with system privileges. The version of Acrobat Pro DC in use is vulnerable to CVE-2019-8195 and CVE-2019-8196, both of which are rated as high/critical risk vulnerabilities with public exploits available.

- CeWL: Custom Wordlist Generator by Robin Wood
- CeWL crawls a target website and collect all web pages and common document formats (MS Office, PDF, images)
 - Extracts content, metadata, and other strings to one or more files
 - Useful to build wordlist from a target site's content and metadata for later attacks (password attacks, host enumeration, and more)

```
$ cewl.rb -m 8 -w whitehouse.txt -a --meta_file whitehouse-meta.txt -e --  
email_file whitehouse-email.txt https://www.whitehouse.gov/  
CeWL 5.5.0 (Grouping) Robin Wood (robin@digi.ninja) (https://digi.ninja/)  
processing file: /tmp/cewl_tmp.pdf  
processing file: /tmp/cewl_tmp.pdf
```

Automating the process of crawling a website and gathering documents and extracting content and metadata is CeWL (Custom Word List generator; the acronym doesn't make sense) by Robin Wood, available at <https://github.com/digininja/CeWL>. CeWL crawls a target website and collects all web pages and several common document formats (primarily targeting Microsoft Office documents, PDF files, and images), as well as HTML body responses. CeWL uses this data to build several lists from the target site including wordlists, email address lists, and metadata-specific information as well (such as Microsoft Office version, PDF publishing software type, and more).

In the example on this slide, we extract information from the target website `whitehouse.gov` (part of the bug bounty target program created by the US SECURE Technology Act of 2019), instructing CeWL to extract any identified words at least 8 characters in length (`-m 8`), saving the words in the file `whitehouse.txt` (`-w whitehouse.txt`). CeWL can also collect metadata (`-a`) and any identified email addresses as well (`-e`).

Reconnaissance with Search Engines

Website Recon

- Google Dorks: Google searches that can reveal vulnerable sites or other useful information to an attacker
- Google Hacking Database: A vast collection of Google Dorks

Google Search Term	Value to an Attacker
site:falsimentis.com intext:@falsimentis.com	Identify any email addresses known for the given domain
filetype:pdf "password" "policy" site:falsimentis.com	Search PDF files for the keywords password and policy for the given domain
"index of /" backup.ab	Identify directory lists where the file backup.ab is present (Android device backups)
filetype:rdp	Identify public Remote Desktop Protocol connection profiles

Fast Google Dorks Scan (FGDS) automates many dork scans (but can get you banned)

Search engines are often the resources of choice for detailed recon activities. Using Google, attackers and analysts alike can identify sensitive information by carefully selecting search terms with modifier keywords including *site* (limit the search to the given domain or subdomain), *intext* (find pages containing one or more words), *filetype* (synonymous with the *ext* term, identifying files by their extension), and more. A maintained list of Google search modifiers is available at <https://ahrefs.com/blog/google-advanced-search-operators/>, written by Joshua Hardwick/@ahrefs.

Using the Google search modifiers, attackers can use Google to identify and collect useful reconnaissance information for a target organization or to identify vulnerable systems for opportunistic target exploitation. There are great resources on this topic including the Google Hacking Database (GHDB) with more than 1,000 different useful searches to locate many problems on target domains. The current home of the GHDB is at the Exploit Database website (<https://www.exploit-db.com/google-hacking-database/>).

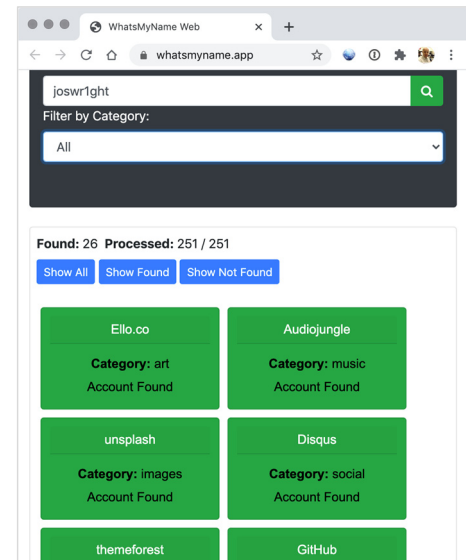
Fast Google Dork Scan (FGDS) is a script that uses Google Dorks and a target domain name to acquire information about a target organization. Written by Ivan Glinkin, FGDS scrapes the results of multiple called Google searches to quickly identify interesting or potentially exploitable services associated with a target domain name. A sample session of using FGDS on Slingshot Linux is available at <https://asciinema.org/a/406990>. Note that, as an automated scanning tool that performs multiple queries in short order, running FGDS can get you temporarily banned from additional Google searches (or require the completion of a CAPTCHA before additional searches are permitted.)

Search engine reconnaissance is categorized as *Acquire OSINT data sets and information* by the MITRE PRE-ATT&CK Framework, ID T1247 (<https://attack.mitre.org/techniques/T1247/>).

Other Website Information

Website Recon

- Public databases
 - SEC's Edgar database
 - Job and professional networking sites (LinkedIn, Indeed, Monster)
 - www.xlek.com
 - namechk.com
 - whatsmyname.app
- Other open-source information
 - Newspapers, blogs, and magazines
 - Social networking sites (what expertise, which friends/associates)



The U.S. *Securities and Exchange Commission* (SEC) can be a useful information source for collecting data for publicly traded US companies. The SEC *Edgar* search engine is available at <http://www.sec.gov/edgar.shtml>.

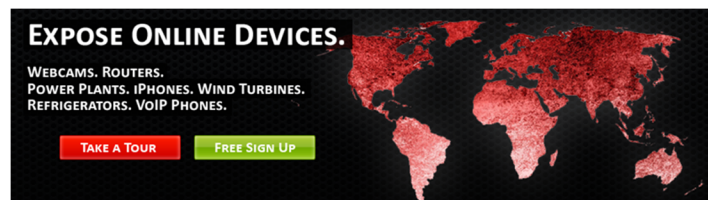
Job site databases can be particularly interesting. If a company is looking to hire a Palo Alto NGFW administrator, the attacker will likely find that type of firewall in the network.

In addition, various other open-source information is available. Newspapers, magazines, blogs, social networking sites, newsgroups, and other sites could provide just the information required by an attacker to launch a more focused attack against your organization.

We can also use sites such as namechk and WhatsMyName.app (<https://www.whatsmyname.app>, written by SANS instructor and author Micah Hoffman) to identify which social networking sites a target user account may be using. WhatsMyName.app searches over 250 sites to identify registered accounts. This can be used by an attacker to develop Social Engineering (SE) pretexts. For example, if users receive an email stating their account with last.fm is about to expire, they are far more likely to click the link if they have an account with that site or service.

This can also be helpful for an attacker to identify which users are more susceptible to SE attacks. Users who are more active online are easier targets because they have a greater predisposition toward clicking links and interacting with strangers.

- Many websites offer the ability to research or even attack other sites
- Links to internet scanning webpages (traceroute, ping, port scans, denial-of-service tests)
 - www.shodan.io
 - www.network-tools.com
 - viewdns.info
 - www.securityspace.com (commercial with free trial)



These websites include forms that allow you to enter a target site and do research or, in some cases, even attacks. These websites can perform DNS lookups, reverse lookups, traceroutes, and a variety of other valuable services. These tools can be interesting to experiment with, remembering that it is the remote website that is performing the reconnaissance scanning or attacking, creating a level of indirection between you and the target website (to avoid detection).

TIP

Use the Shodan advanced search operators `org`, `net`, and `port` to find known targets within your own organization. Negate searches with an exclamation point.

One of the main tenets of being a malicious attacker is not getting caught. But how exactly is an attacker to find vulnerabilities and not touch a network or target system? One of the answers is Shodan. Shodan is an online service that crawls the internet in much the same way Google crawls web pages. Instead of reading and indexing web page text, like Google, Shodan indexes service banners. Banners for services like FTP and Telnet will often have a unique signature to identify that service, vendor, and version number. All an attacker, or enterprising defender, needs to do is search for a string associated with a service and vendor, and Shodan will display its cached results. This service can also be restricted to specific network ranges so a defender can see what Shodan has discovered about your organization.

Check it out at <https://www.shodan.io>. A cheat sheet with Shodan search terms and modifiers (e.g., restricting your search to specific cities, or only targets where Shodan has captured a device screenshot) is available from Bradley Thornton at https://thor-sec.com/cheatsheet/shodan/shodan_cheat_sheet/.

You can negate any search term by including a leading exclamation point before the term. For example, to identify Shodan targets between the IP addresses 8.8.0.1 - 8.8.255.254 (a CIDR mask of 8.8.0.0/16) with screenshots that are NOT listening on TCP port 80, you could enter: `net:8.8.0.0/16 has_screenshot:true !port:80`.

- Limit and control information
 - Know what information is given away and perform risk analysis
- Limit data indexed by search engines using robots.txt
 - Be careful not to point attackers to your sensitive data
- Look for web spider/crawler activity
 - Logs show systematic access of entire website, page by page

```
User-agent: *
Disallow: /registration
Disallow: /admin.php
Disallow: /app
Sitemap: https://www.sans.org/sitemap-index.xml
```

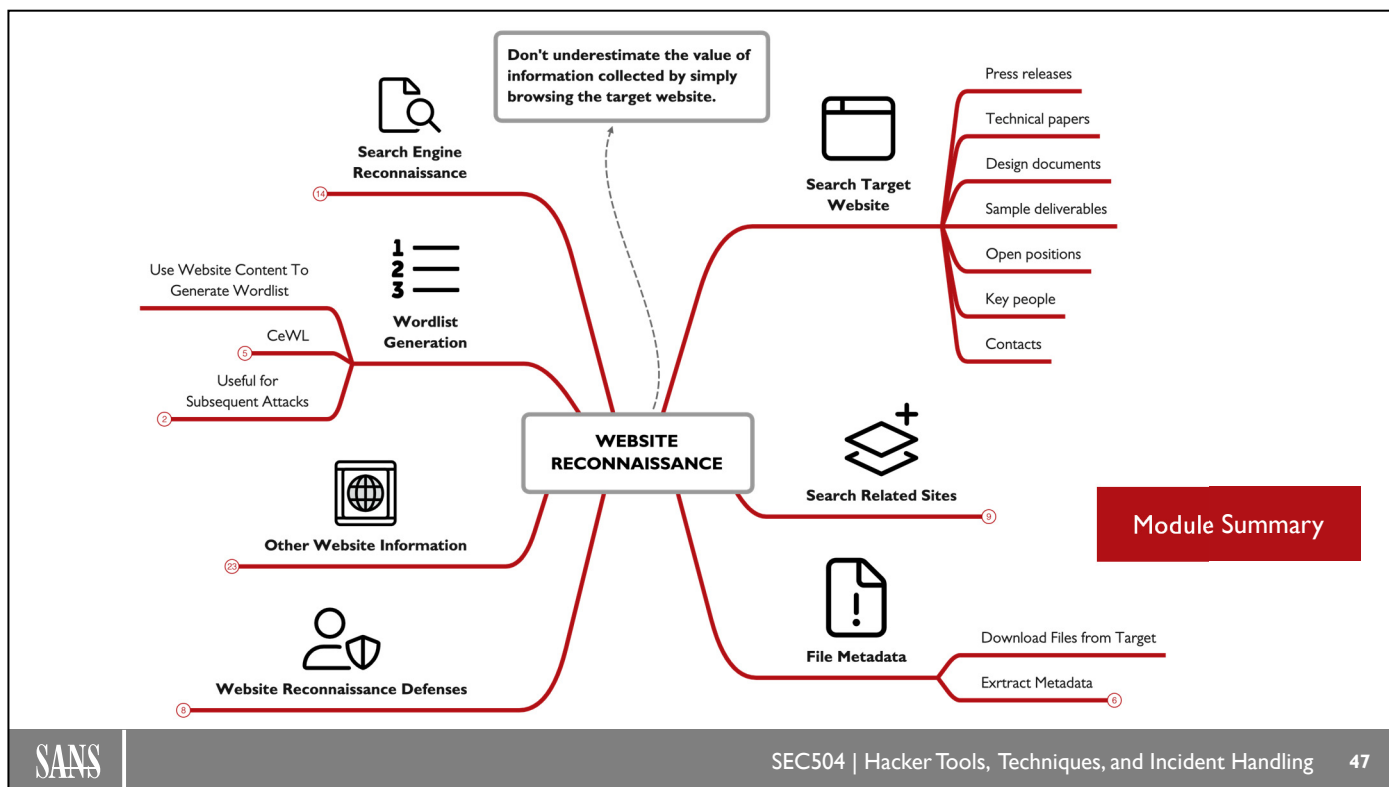
You should periodically check various open sources of information to see what your company is leaking. This analysis can be done by the security organization, legal department, and public relations because all have a vested stake in protecting your corporate information.

You can limit what Google and other search engines crawlers record about your website by adding a robots.txt file in the root directory of the web server (e.g., if your website is www.sans.org, the robots.txt file is located at www.sans.org/robots.txt). The contents of the robots.txt file is collected by search engine crawlers prior to collecting information from your site; any URLs identified with a `Disallow:` keyword (e.g., `Disallow: /wp-admin`) will not be collected by the search engine crawler. Additional information about the configuration of the robots.txt file is available at <https://developers.google.com/search/docs/advanced/robots/create-robots-txt>.

While the robots.txt file can be useful to prevent search engines from indexing resources on your organization's web servers, it can also be an informative resource for an attacker. For example, consider a case where a web server administrator configures the robots.txt file with the entry `Disallow:`

`/admin/8c5b220bf6f482881a90287a64aea150` to prevent search engine crawlers from indexing any content in the administration section of the website for the file with a random file name. An attacker who targets the site can requests the robots.txt file just as any search engine crawler can, thereby disclosing the presence of the page. As a rule, deny search engine crawlers from indexing sensitive content using the robots.txt file, but do so using high-level directories (e.g., `Disallow: /admin` instead of `Disallow: /admin/8c5b220bf6f482881a90287a64aea150`).

For identification, have your web administrators look through their logs for an indication that someone has used a web spider (also known as a web crawler) to access every page on your site in a short period of time (say, within five minutes). Most likely, this activity is just the crawler of a search engine (like the Google bot). From another source, however, it could be a sign of pre-attack recon.



This visual association summary is included in your ISO media files as Summary-WebsiteReconnaissance.pdf

In this module we investigated the topics surrounding website reconnaissance analysis. Defenders should not underestimate the value of information collected by simply browsing the target website, and how an attacker might leverage that information.

In this module we looked at website reconnaissance techniques including searching the target website for public data resources such as press releases, technical papers, design documents, sample deliverables, open positions, key people/employees, and contact information. We also reviewed the value of identifying related sites, such as business partners, subsidiaries, and suppliers.

In addition to retrieving and viewing content from a target website, we looked at the value of examining metadata associated with retrieved files. Using `exiftool`, an attacker can gather sensitive data from image files, Microsoft Office documents, PDF files, and more. This data can disclose sensitive information, such as name, email address, and software version information which may highlight vulnerable systems within the organization.

Attackers can leverage tools to accelerate the data collected from a target website, normalizing it into a format that can be utilized with other attack tools. One example is CeWL, the custom wordlist generator. CeWL will crawl a website to extract content from MS Office, PDF files, and images, extracting the file content, metadata, and other strings to build a word list and optionally a list of email addresses. These lists can then be used in later attacks including password guessing attacks.

Website reconnaissance techniques can be applied using search engines as well, leveraging search engine modifiers to influence the search result, and through the application of Google Dorks: Google searches that reveal vulnerable sites. Further, third-party websites may also provide valuable sources of data for an attacker, such as job posting sites, professional networking sites, and more. We reviewed the use of web-based attack sites that abstract the attack techniques using a web interface or provide the attacker with detailed data collected in advance such as the Shodan website.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

...

DNS Interrogation

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

Lab: Cloud Scanning

SMB Security

Lab: SMB Security

Defense Spotlight: DeepBlueCLI

Lab: Windows Password Spray Attack Detection

Next, we'll look at the steps an attacker can use to scan networks and hosts using Nmap.

- An attacker wants to understand the topology of the target network:
 - Internet connectivity, perimeter networks
 - Internal network (with access from modem or wireless access point)
 - Can reveal vulnerabilities (or at least disclose the network architecture)
- Nmap can be used for network mapping and port scanning
 - Written by Fyodor and the Nmap development team
 - Available for Linux and Windows; Zenmap GUI for visualization
 - We will look at network mapping first, and then port scanning

Nmap is an essential tool for attackers and defenders alike!

An attacker wants to understand the topology of your network, mainly internet connectivity: perimeter networks, and your internal network segments. The layout of routers and hosts can show vulnerabilities, or at least let the attacker know where things are.

Nmap, the popular network analysis tool by Fyodor and the Nmap development team, can be used for network mapping and port scanning, although most people associate it with the latter. Nmap is designed as a command-line tool, but also includes a GUI-based frontend called Zenmap, which provides excellent network mapping and visualization features. Nmap is available for free from nmap.org.

Nmap is an essential tool, used by attackers and administrators alike. In this section we will look at using Nmap for network mapping first, and then for port scanning.

Network mapping is categorized as *Network Service Scanning* by the MITRE ATT&CK Framework, ID T1046 (<https://attack.mitre.org/techniques/T1046/>).

Sweeping for Network Mapping

Nmap

- Sweeping through address space to identify active hosts on the network
- Attacker sends an ICMP echo request to a range of IP addresses
 - If something replies, that address is in use by some target system
 - If nothing replies, that address is not in use, or there is network filtering
- By default, Nmap sweeps each target address before port scanning it
 - This can be ignored altogether (the -Pn flag in Nmap)
 - Run the Nmap sweep as root for best results

TIP

Nmap sends four packets to identify UP hosts when run as a privileged user:

- ICMP Echo Request
- TCP SYN to port 443
- TCP ACK to port 80
- ICMP Timestamp Request

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

50

A common initial step in network mapping is to sweep through the target network addresses, sending one or more packets to each address watching for a response. The response indicates that the given address is in use by some target system.

By default, Nmap sweeps through each target address before it launches a port scan of the address. However, this scanner behavior can be reconfigured so that all addresses are scanned, regardless of whether they are *pingable* or not. In Nmap, the -Pn command flag tells Nmap not to ping the target, but to just start the port scan.

By default, to identify which addresses are in use, Nmap sends the following four packets to each address in the target range: ICMP Echo Request, TCP SYN to port 443, TCP ACK to port 80 (if Nmap is running with UID 0), and an ICMP Timestamp request. If Nmap is not running as root on a Linux system, it only sends a TCP SYN to port 80 and to port 443 (as non-root, Nmap cannot craft the ACK packet sent to port 80). If any of those packets receives a response, Nmap assumes the address is in use and continues with the port scan. Due to the limitations of running the Nmap host discovery as non-root, we recommend running Nmap as root for the best host discovery results.

Nmap Host Discovery

Nmap

```
sec504@slingshot:~$ sudo nmap -sn 192.168.1.1-254
```

```
Starting Nmap 7.60 ( https://nmap.org ) at 2021-07-03 14:58 UTC
Nmap scan report for 192.168.1.1
Host is up (0.0081s latency).
Nmap scan report for 192.168.1.10
Host is up (0.0065s latency).
Nmap scan report for 192.168.1.27
Host is up (0.010s latency).
Nmap scan report for 192.168.1.34
Host is up (0.91s latency).
Nmap scan report for 192.168.1.70
Host is up (0.0040s latency).
...
Nmap done: 254 IP addresses (20 hosts up) scanned in 18.00 seconds
```

Nmap's `-sn` option disables port scanning and focused solely on host discovery. Best run with root privileges.

The example on this page shows a sample output of Nmap perform host discovery. By running the scan with the `-sn` argument, Nmap will disable port scanning functionality and will focus solely on host discovery. In the scan results we see a list of hosts that respond to at least one of Nmap's four host discovery tests, and a latency measurement. Note that, for best results, Nmap should be run with root privileges to send all four host discovery tests.

In the result here we see the identified host list, but we don't see an indicator that reveals which of the four host discovery tests revealed the presence of each host. To see this additional information, add the `--reason` argument to the Nmap command line.

Closer Look at the IP Header

Nmap

Vers	Hlen	Service Type	Total Length	
Identification			Flags	Fragment Offset
Time to Live	Protocol	Header Checksum		
Source IP Address				
Destination IP Address				
IP Options (if any)				Padding
Data				
.....				

IPv4 Header Detail

Vers	Class	Flow Label		
Payload Length		Next Header	Hop Limit	
Source IP Address				
Destination IP Address				

IPv6 Header Detail

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

52

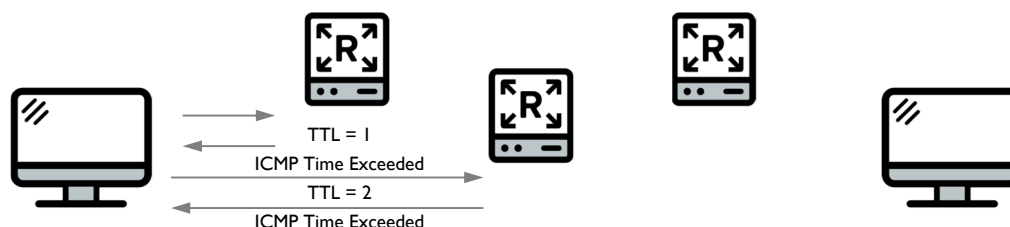
This slide shows the IP packet header (for IPv4 and IPv6), highlighting the key areas associated with mapping a network. The source and destination IP address are of interest to us at this point, as well as the Time to Live (TTL) field for IPv4 and the Hop Limit field for IPv6. The source IP address indicates from where the packet comes. The destination IP address identifies where it's going.

The Time to Live field in IPv4 and the Hop Limit field in IPv6 both indicate how many hops the packet can go across the network before it's discarded. Let's explore TTL in more detail to see how traditional tracerouting works for network mapping, as manifested in the Linux and UNIX traceroute command and the Windows tracert command. In this discussion, the IPv6 Hop Limit field behaves exactly like the IPv4 Time to Live field.

How Traditional Traceroute Works

Nmap

- Traceroute sends packets with small Time to Live (TTL) values
- IPv4 TTL and IPv6 Hop Limit is the number of hops the packet should go before being discarded
 - If exceeded, the router returns an ICMP TTL-Exceeded message
- Based on the source address of the TTL-exceeded message, you can determine the router for a given hop



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

53

How do the IPv4 TTL field and IPv6 Hop Limit field work? When a router receives an incoming IP packet, it first decrements the value in the TTL (or Hop Limit) field by 1. For example, if the incoming packet has a TTL value of 29, the router sets it to 28. Then, before sending the packet on toward its destination, the router inspects the TTL field to determine if it is zero. If the TTL is zero, the router sends back a Time Exceeded message to the originator of the incoming packet, saying, "Sorry, but the TTL wasn't large enough for this packet to get to its destination." TTL was created so that packets would have a finite lifetime (up to 255 hops), and we wouldn't have packets circling the internet for eternity.

This TTL field is especially useful in determining how the various parts of a network are interconnected. The Linux and UNIX traceroute command, the Windows tracert command, and Nmap all rely on making variations in this field during network mapping to measure the paths that packets take across the network.

By sending a series of packets with various TTL values, the traceroute and tracert tools identify all routers from a given source to any destination. As shown in the slide's graphic, they start out by sending a packet from the source system with a TTL of one. The first router receives the packet, decrements the TTL to zero, and sends back a Time Exceeded message. What is the source address of the Time Exceeded message? It's the IP address of the first router on the path to my destination. Bingo! I know the address of the first router on the way to my destination. Next, I send out a packet with a TTL of 2. The first router decrements the TTL to 1 and forwards the packet. The second router in the path decrements the TTL to zero and sends a Time Exceeded message. I now have the address of the second hop. This process continues as I send packets with higher TTLs until I reach my destination. At that point, I know every hop between me and my target. The traceroute and tracert commands determine whether to use IPv4 or IPv6 based on the format of the IP address they are provided. However, you can force traceroute or tracert to use IPv4 by using -4 in your command and force IPv6 using -6.

```
sec504@slingshot:~$ sudo nmap -sn --traceroute 216.239.191.182-200 -oA insecure-net
```

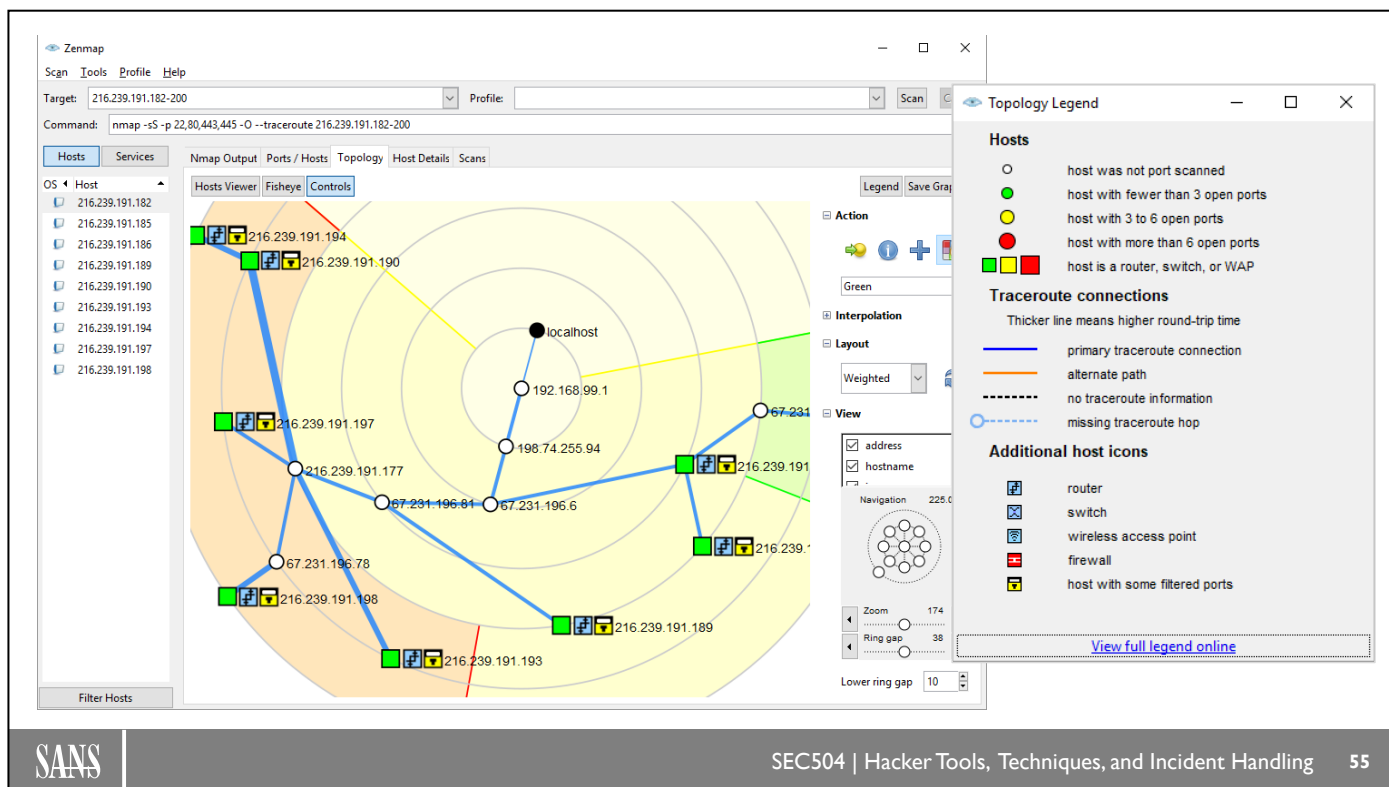
```
Starting Nmap 7.60 ( https://nmap.org ) at 2021-07-03 15:23 UTC  
Nmap scan report for 216.239.191.182  
Host is up (0.044s latency).
```

```
TRACEROUTE (using proto 1/icmp)
```

HOP	RTT	ADDRESS
1	1.90 ms	unifi.localdomain (192.168.1.1)
2	1.97 ms	172.16.0.1
3	12.48 ms	216.239.191.190
4	11.28 ms	b3316.prvdri-lcr-21.verizon-gni.net (100.41.212.234)
6	12.78 ms	0.ael.brl.bos30.alter.net (140.222.236.253)
7	10.93 ms	verizon-com.customer.alter.net (204.148.29.218)
9	41.03 ms	4.59.240.226
10	37.62 ms	67.231.196.86
11	49.04 ms	216.239.191.185
12	105.91 ms	216.239.191.198
13	52.95 ms	216.239.191.193

By adding --traceroute we get network hop results; adding -oA logs all results to the file prefix insecure-net

In the example on this page, we perform another host discovery scan (using `-sn` to disable port scanning), this time adding `--traceroute` as an argument to have Nmap record the path to each discovered host when it responds as up. We scan a range of hosts in this example, and record the results using `-oA`, which will use the filename prefix to record the scan results as an XML file in addition to `.nmap` (matching the standard output for Nmap) and `.gnmap`, which is a grep-friendly result log file.



Once Nmap finishes conducting a network sweep and its tracerouting activities, the Zenmap GUI can provide an interactive graphical portrayal of the network. This output is a cumulative view of recent scans conducted by Nmap, showing each system identified during ping sweeping, along with the series of connections between the systems.

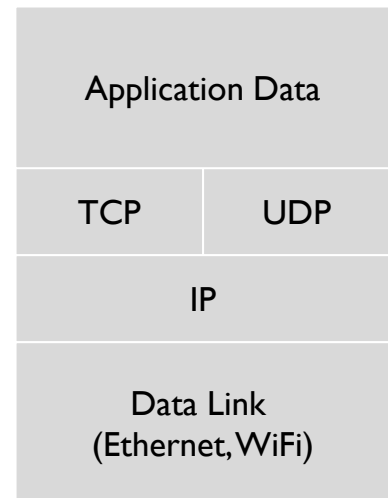
The Zenmap graphical view allows for zooming into targets or specific parts of the network. The user can simply double-click a host to move it to the center of the map. There is also a fisheye view that lets the user have one part of the network map zoomed in while making other parts of the graph smaller. You can also color-code different sections of the map based on the selected host or router, making it possible to also use Zenmap as a tracking tool.

On the left-hand side of the display, we can see each host with a graphical depiction of its operating system type, discovered using the active OS fingerprinting features of Nmap that we discuss later.

Port Scanning

T1046

- Port scanners are a must for any attacker's toolbox
- They help identify openings on a system and the type of system
 - Allowing an attacker to focus an attack
- Most internet applications use TCP or UDP
 - TCP: *Connection-oriented* (sequence preserved and retransmitted if needed)
 - UDP: *Connection-less* (get it there if you can)



To understand port scanners, we first need to do a brief protocol review.

The Internet Protocol (IP) is the common protocol used to move information around the internet. IP includes the source and destination address of each packet. The Transmission Control Protocol (TCP) and User Datagram Protocol (UDP) ride on top of IP. That is, TCP and UDP messages are plopped inside of an IP message. TCP is *connection-oriented* in that it applies sequence numbers to messages and tries to deliver them in the appropriate order. It also resends dropped messages. UDP is connection-less, in that it makes a best-effort delivery, but messages may be dropped or delivered out of order.

If someone is going to access your system, ports are the entry points or the doors and windows into your system. A list of open ports gives an attacker various possible avenues for compromising the system.

Port scanners are a must for any attacker's toolbox. They help identify openings on a system and the type of system and allow an attacker to focus their attack on specific services.

Port scanning is categorized as *Network Service Scanning* by the MITRE ATT&CK Framework, ID T1046 (<https://attack.mitre.org/techniques/T1046/>).

- TCP and UDP have ports: A field in the TCP and UDP headers
 - Total of 65,536 (times 2) ports
 - Port 0 is invalid; any packet with port 0 should be dropped
- Port scanners send packets to various ports to determine what is listening
 - Find TCP 80, web server
 - Find TCP 445, Windows Server Message Block
 - Find UDP 53, DNS server
 - And more
- But these all can change!

There are 2^{16} (65,536) different TCP ports and 65,536 different UDP ports. Common services listen at well-known port numbers. The latest port listing is maintained by the IANA. For example:

- TCP 80 usually indicates a web server
- TCP 445 usually indicates Windows Server Message Block (SMB)
- UDP 53 usually indicates a DNS server
- TCP 6000 usually indicates an X Window server

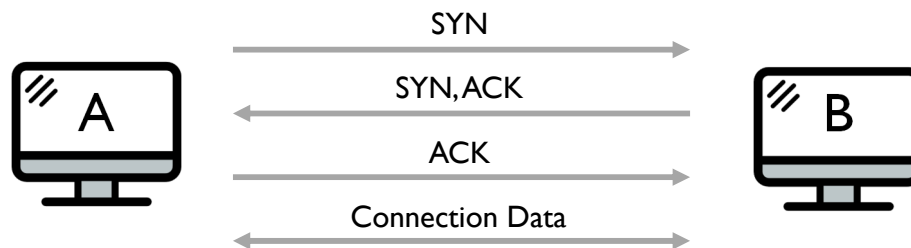
Each open port (for example, listening) offers a potential way into a system.

Although we sometimes see traffic with a source or a destination port of 0, these packets are always invalid. TCP port 0 is not supported as a listening service, and any packets to or from port 0 should be dropped.

TCP Three-Way Handshake

Nmap

- Initial SYN establishes sequence number for A to B
 - Usually, B must remember this allocating state in its connection queue
- Response SYN-ACK establishes sequence number for B to A



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

58

All *legitimate* Transmission Control Protocol (TCP) connections (for example, HTTP, Telnet, FTP, and so on) are established through this three-way handshake.

The handshake allows for the establishment of sequence numbers (with a sequence number starting in both SYN packets known as the *Initial Sequence Number* or ISN) between the two systems. These sequence numbers allow TCP to provide reliable packet delivery in sequential order where both sides expect the next packet to arrive following a sequence number order. Sequence numbers also accommodate retransmission of packets that are not received.

Six control bits describe the packet's role in the connection:

- **SYN**: Synchronize
- **ACK**: Acknowledgment
- **FIN**: End a connection
- **RESET**: Tear down a connection
- **URG**: Urgent data is included
- **PUSH**: Data should be pushed through the TCP stack

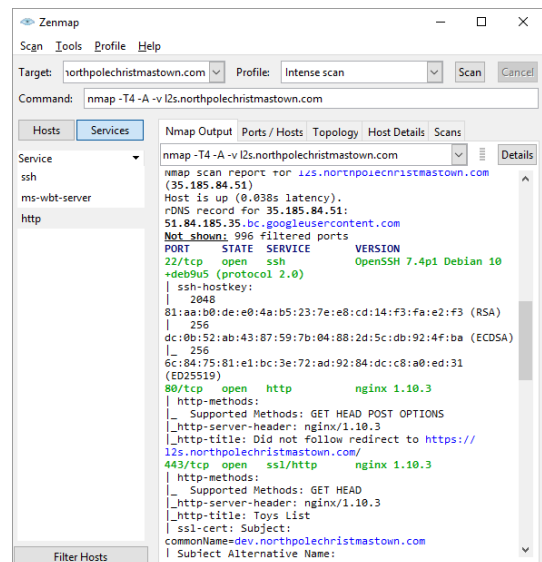
Note that the control bits can be set independently of one another. For example, you could have a SYN-ACK packet with both bits set.

Nmap: Scan Types

Nmap

- Ping sweeps and ARP scans
- TCP connect scans (three-way handshake)
- TCP SYN scans (*half-open* scans)
- UDP scanning
- Version scanning
- Many more scan types as well!

IPv6 scanning (-6) supports all scan types



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

59

Nmap allows for conducting several types of scans:

- **Ping sweeps:** Send a variety of packet types (including ICMP Echo Requests, but many others as well).
- **ARP scans:** Identify which hosts are on the same LAN as the machine running Nmap. The ARP scan does not work through a router because ARP traffic just goes on a single LAN.
- **TCP connect scans:** Complete the three-way handshake. Because the entire handshake is completed for each port in the scan, the activities are often logged on the target system. This is the default scan type used when Nmap is run without root or Administrator access.
- **TCP SYN scans:** Only send the initial SYN and await the SYN-ACK response to determine if a port is open. The final ACK packet from the attacker is never sent. The result is an increase in performance over a TCP connect scan due to the reduced number of packets sent. Because most host systems do not log a connection unless it completes the three-way handshake, the scan is less likely to be detected.
- **UDP scanning:** Helps locate vulnerable UDP services. For most UDP ports, Nmap sends packets with an empty payload. But, for about a dozen specific ports, Nmap includes an application-appropriate payload for the given port, including UDP port 53 (DNS), 111 (portmapper), 161 (SNMP), etc.
- **Version scanning:** Tries to determine the version number of the program listening on a discovered port for both TCP and UDP.
- **IPv6 scanning:** Iterates through a series of IPv6 addresses, scanning for target systems and ports, invoked with the -6 syntax. Today, all Nmap scan types support a -6 option.

Nmap also supports many other scan types as well. The definitive source of detailed information on Nmap scan type features is available on the Nmap website at <https://nmap.org/>.

```
sec504@slingshot:~$ sudo nmap -sS 192.168.1.10 -oA target-host
Starting Nmap 7.60 ( https://nmap.org ) at 2021-07-03 18:12 UTC
Nmap scan report for 192.168.1.10
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
5000/tcp  open  upnp
```

Adding -sV tells Nmap to conduct a version scan, gathering information from open ports to interrogate the service and present more detail.

```
sec504@slingshot:~$ sudo nmap -sS -sV 192.168.1.10 -oA target-host
Starting Nmap 7.60 ( https://nmap.org ) at 2021-07-03 18:12 UTC
Nmap scan report for 192.168.1.10
80/tcp    open  http      nginx
139/tcp   open  netbios-ssn?
443/tcp   open  ssl/http   nginx
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
5000/tcp  open  http      nginx
Service Info: Host: DISKSTATION; OS: Unix
```

In the example at the top of this page we perform a SYN scan using Nmap `-sS` argument, targeting the host at 192.168.1.10, instructing Nmap to save the results to the target-host filename prefix. We see that the target system returns information about several ports including the corresponding service information associated with the port using a list of services in the `nmap.services` file.

At first glance we might take this system for a Windows host, notably due to the presence of the SMB ports TCP/139 and TCP/445. However, consider the output on the bottom of page when we add the `-sV` *version scan* argument. When we request a version scan, Nmap will not only identify the open ports, but will also connect to each port and *probe* the service to obtain a response. The response information gives Nmap more information to work with, identifying additional information such as the web server type (Nginx), and that the SMB service running on TCP/445 is a Samba server. Further, the service information provided at the end of the version scan output indicates that the hostname is DISKSTATION, on a UNIX platform.

The Nmap version scan information is useful, but at a cost: it is slower than other scan types, and it will generate more network activity, potentially disclosing the attacker's presence.

Nmap Scripting Engine: Identify Host Information, Vulnerabilities

Nmap NSE Argument	Function
-sC	Use default scripts to evaluate the target
--script all	Run all scripts against target (can lead to DoS)
--script-updatedb	Update the NSE scripts (requires internet access)
--script banner	Run the named script (<i>banner</i>) against the target(s)
--script-help "http*"	Get help for the named script(s) (use wildcard * alone for all scripts)
--script "http*"	Run all the scripts beginning with http against the target(s)
--script "smb*"	Run all the scripts beginning with smb against the target(s)

In addition to host and network enumeration, Nmap also included support for the *Nmap Scripting Engine* (NSE). NSE is a library of scripts written in the Lua scripting language designed to take the output of Nmap scanning and further assess a target system to collect information and identify vulnerabilities. Adding the `-sC` argument will instruct Nmap to use the *default* category of scripts to collect additional information about the target(s) (additional categories for scripts include *all*, *auth*, *discovery*, *external*, *intrusive*, *malware*, *safe*, and *vuln*).

Several useful examples of Nmap arguments relating to NSE functionality are shown on this page. Some NSE scripts also expect arguments (which can be identified by looking at the help information associated with the script). To specify an argument for a NSE script, use the `--script-args` argument, followed by the argument name, an equal sign, and the argument value. You can specify several arguments on the command line by separating them with commas.

```

sec504@slingshot:~$ sudo nmap -p 5000 -sV 192.168.1.10 --script http-
security-headers -oA target-host-secheaders

PORT      STATE SERVICE VERSION
5000/tcp  open  http    nginx
...
|   X_XSS_Protection:
|     Header: X-XSS-Protection: 1; mode=block
|     Description: The browser will prevent the rendering of the page when
XSS is detected.
|   X_Content_Type_Options:
|     Header: X-Content-Type-Options: nosniff
|     Description: Will prevent the browser from MIME-sniffing a response
away from the declared content-type.
|   Cache_Control:
|     Header: Cache-Control: no-store
|_ http-server-header: nginx

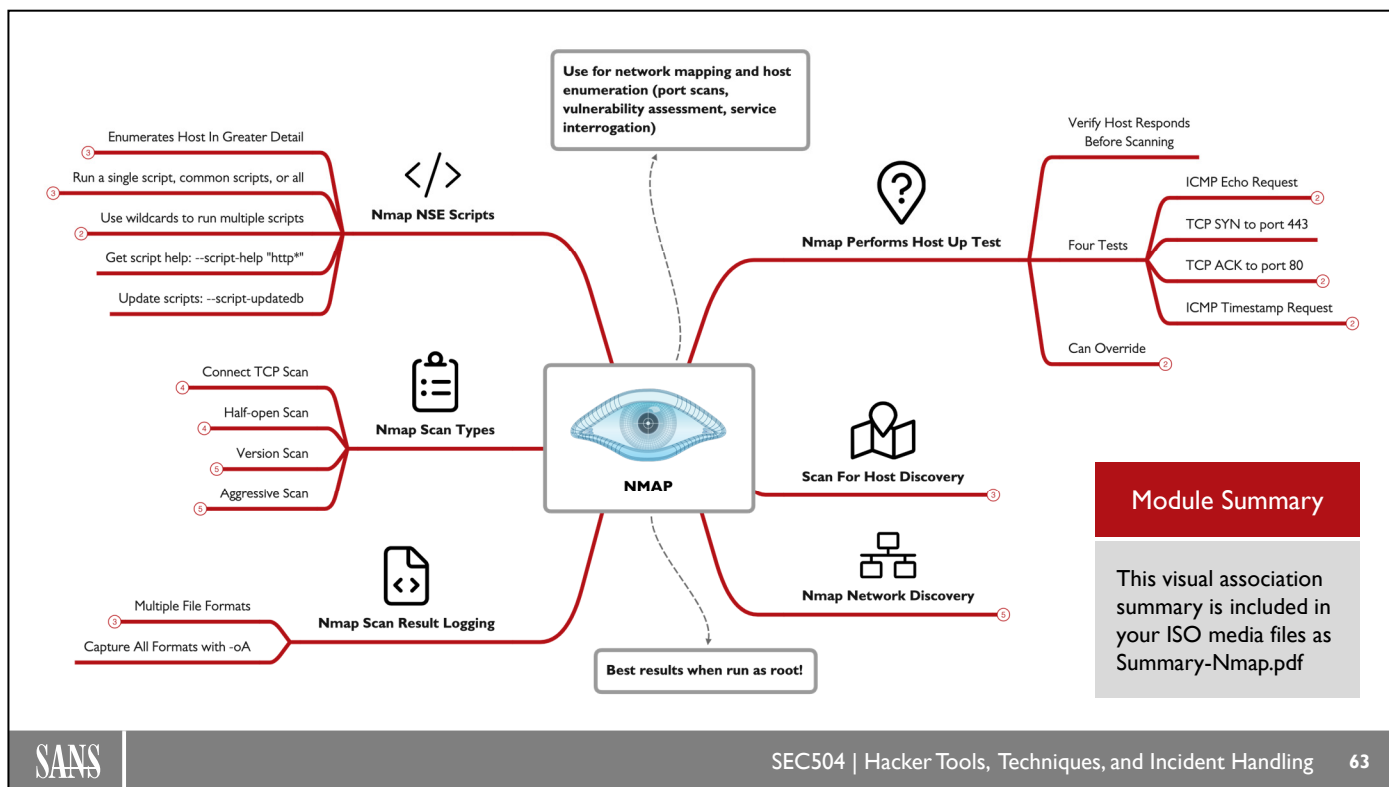
Nmap done: 1 IP address (1 host up) scanned in 14.28 seconds

```

In the Nmap example on this page, we reduce the number of ports for the scan to a single port identified with `-p 5000`; since we already have scan results for this system, we don't need to scan the ports again. We can optionally specify multiple ports with `-p` using a hyphenated range or comma-separated values (e.g., `-p 80,5000`).

The output from this command is long and we've modified it to fit in the space available here. The `--script` argument allows us to specify one or more scripts (using script name wildcards, or multiple `--script` command line parameters); here we've asked Nmap to interrogate the security headers used for the web server to give us an idea of what the server defenses may be for attacks.

TIP: One important consideration for using Nmap NSE scripts is to always conduct the scan using the version scan `-sV` argument. Consider what would happen if we omitted `-sV` here: Nmap would believe port 5000 to be UPNP service based solely on the `nmap.services` lookup file, and not apply the `http-security-headers` script to the service, thinking the port was not HTTP. When using Nmap scripts, it's typically a good idea to add the `-sV` argument as well.



In this module we investigated the topics surrounding network mapping and host enumeration using the powerful Nmap tool. Nmap is well known for its capabilities in enumerating networks for host discovery and mapping out network nodes using traceroute enumeration, as well as for enumerating detailed information from individual host systems. We examined how the Nmap tool first performs a host *up* check, to determine if the host is present on the network before scanning it in more detail. The host up check uses four packets: ICMP echo request, ICMP timestamp request, TCP SYN to port 443, and TCP ACK to port 80. This host up check can change depending on whether Nmap is run as root (with the advice that Nmap produces the best results when run with root privileges).

Depending on the goals of the attacker, Nmap offers multiple scan types. Nmap supports multiple scan types to identify TCP and UDP ports on a target system but can also interrogate the system in more detail by conducting a *version* scan (`-sV`), or an *aggressive* scan (`-A`).

Nmap's scan results can also be logged using multiple file formats with the `-oA` argument, capturing data in XML, standard Nmap output, and grep-friendly files. The XML data in particular, is useful since it can be visualized in the Zenmap GUI companion tool to Nmap.

The aggressive Nmap scan utilizes Nmap Scripting Engine (NSE) scripts to conduct additional interrogation on a target system. NSE scripts can be used for enhanced host interrogation, but also for vulnerability discovery and several attacks as well. NSE scripts can be run one a time, or as a group specified using wildcards with the `--script` argument.

LAB

Please work on the lab exercise
Nmap



Please work on the lab exercise *Nmap*. For this lab exercise you will need your class Slingshot Linux VM and the class Windows VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

...

DNS Interrogation

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

Lab: Cloud Scanning

SMB Security

Lab: SMB Security

Defense Spotlight: DeepBlueCLI

Lab: Windows Password Spray Attack Detection

Next, we'll look at the steps an attacker will use to perform scanning against a cloud environment in our *Cloud Spotlight* module: Cloud Scanning.

- Enumerating cloud targets introduces new challenges
 - Impractical to scan large ranges of IPs
 - Difficult to identify owner of a given target
- Cloud target enumeration also has new attacker opportunities
 - Less likely to be monitored and logged
 - Potential to bypass ACL filters
 - May reveal information about non-cloud assets

NOTE

Cloud target enumeration should always be done using the same cloud provider. This improves performance and can often evade firewalls that permit access sourced within the cloud infrastructure.

In this module we will continue our look at scanning techniques, but we will focus on how an attacker can use scanning to identify cloud target systems. Scanning cloud target systems introduces new challenges for the attacker, but also new opportunities as well.

For an attacker, it is impractical to scan a large range of IP addresses associated with a cloud provider using conventional techniques. Even with scan results, an attacker must find a way to differentiate a given target from other customers on the same cloud provider (e.g., *is this IP address listening on TCP/443 my target, or a different cloud customer?*)

Despite these challenges, attackers will scan for and enumerate cloud assets as additional target opportunities. One benefit for the attacker is that the networks for cloud targets are less likely to be monitored and logged by the target organization. An attacker may also be able to bypass firewall filters if they scan from within the same cloud provider network. Finally, the cloud systems may reveal information about non-cloud infrastructure, expanding the scope of attack opportunity for an adversary.

In this module we'll look at the techniques attackers use to scan large ranges of cloud provider IP addresses to identify additional targets for attack. While we are applying it to the context of our Cloud Spotlight material, these same techniques can be used for non-cloud scanning as well when there are a larger number of hosts to scan (such as scanning a large internal network) where Nmap would be too slow to be effective. Much of this module is inspired by the excellent article *How To Scan AWS's Entire IP Range to Recon SSL Certificates* by Daehee Park (<https://www.daehee.com/scan-aws-ip-ssl-certificates/>).

Cloud and internal network targets are categorized as *Network Service Scanning* by the MITRE ATT&CK Framework, ID T1046 (<https://attack.mitre.org/techniques/T1046/>).

If you work with cloud systems, you'll have to work with JSON

- JSON is an ASCII-based data format widely used by cloud providers
 - You *can* use grep/cut/awk/sed to process JSON, but it's not ideal
- JSON Query (JQ) is a tool designed to work with JSON data
 - Straightforward use case: Format JSON for easier reading
 - Advanced use case: Perform functions on selected data in JSON
- Recommendation: Practice the steps in the JSON bootcamp following this module

Whether you work in defense, offense, or purple team – if you work with cloud systems, you'll have to work with JSON. JSON is a popular, ASCII-based data format widely used by cloud providers for provisioning assets, managing users, and monitoring systems. JSON data is widely used by AWS, Google Cloud Platform, Azure, and other cloud providers as well.

Since JSON data is ASCII-based, you can try to process it with common text processing tools such as grep, cut, awk, and sed. However, this is not ideal, since JSON data is not constrained to any consistent line ending expectations (indeed, some complex JSON files are only a single line of text; a very long, single line of text). A better alternative to processing JSON data is the JSON Query tool, JQ.

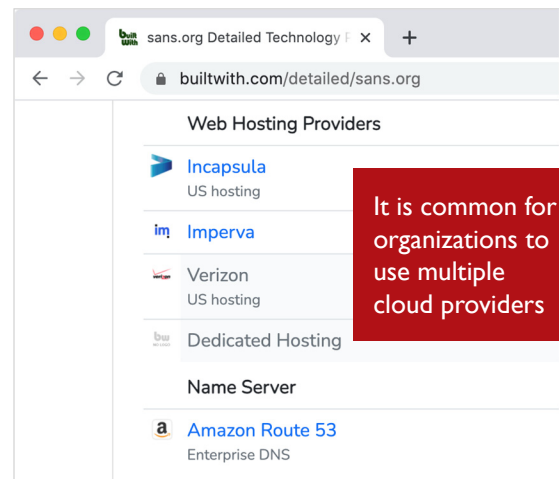
JQ is a lightweight tool and programming language for parsing, interrogating, and editing JSON data, written by Stephen Dolan (available at <https://stedolan.github.io/jq/>). Although it is technically a *programming language*, JQ can be easy to get started with, making it possible to take complex JSON data and format it for easy reading. JQ can also be quite complex, using a variety of different built-in and custom functions to process JSON data.

In much of our content relating to cloud systems, JSON data examples are introduced. If you haven't used JQ before, I recommend you spend some time practicing the JSON bootcamp where you'll have a chance to learn about basic and intermediate JQ functionality.

Cloud Scanning Process

Cloud Scanning

- Using reconnaissance, attacker identifies likely cloud provider
 - DNS information, linked resources in website pages, etc.
 - Builtwith.com summarizes service providers for a given site
- Attacker identifies IP range for provider, performs full scan
- Leverages scan results to identify other systems for target discovery



Before we look at the cloud scanning process, it's important to point out that scanning is just one technique attackers use to identify cloud assets. Attackers will often use reconnaissance analysis and OSINT data to identify a cloud provider used by a target organization, leveraging DNS information, linked information in website pages (content delivery network/CDN references, distributed denial of service/DDoS providers, etc.), and public websites that can automatically identify the hosting provider.

The BuiltWith site reports on trends for internet technology, including analytics providers, CDN providers, and hosting providers including cloud services. Visiting builtwith.com and searching for a domain name will disclose several characteristics of the target website including the cloud providers in the *Web Hosting Providers* section of the report. The example on this page shows the result of searching for the sans.org domain, revealing several different providers including the Amazon AWS Route 53 DNS service. Like many other sites, sans.org uses several different cloud providers together.

An attacker that uses reconnaissance and OSINT resources can determine which cloud providers are in use at a target organization. Once the attacker identifies the cloud providers, they can dive into a deeper scan to identify even unlinked systems.

Exhaustive IP Address Enumeration

Cloud Scanning

Cloud providers publish lists of their cloud IP addresses in JSON format

Google Cloud Platform

```
$ wget -qO- https://www.gstatic.com/ipranges/cloud.json | jq '.prefixes[] | .ipv4Prefix' -r
```

Amazon AWS

```
$ wget -qO- https://ip-ranges.amazonaws.com/ip-ranges.json | jq '.prefixes[] | .ip_prefix' -r
```

Azure (download first)

```
$ jq < ~/Downloads/ServiceTags_Public_*.json '.values | .[] | .properties.addressPrefixes | .[]' -r
```

An attacker may choose to focus on a specific part of the cloud provider network to match the target organization's deployment region.

One of the premises of scanning is that the attacker will have a range of IP addresses to scan, or even a host name that can be converted into an IP address. The same concept applies to cloud scanning: once the attacker identifies the cloud provider, they need to identify the IP addresses associated with the cloud services to conduct a detailed scan.

Fortunately, cloud providers publish lists of their IP addresses in easily-parsed JSON format. This information is needed by many companies as part of their continuous integration (CI) build process for network security, as well as for responding to attacks seen from different cloud providers.

This page shows three examples of retrieving cloud provider IP addresses using the hosted lists using the Wget and JQ tools (note that for Azure, you must download the IP address list manually from <https://www.microsoft.com/en-us/download/details.aspx?id=56519> then parse the extracted file with JQ). The short JQ programs will extract only the IP address and Classless Inter-Domain Routing (CIDR) mask information:

```
$ wget -qO- https://ip-ranges.amazonaws.com/ip-ranges.json | jq '.prefixes[] | .ip_prefix' -r | head -3
3.5.140.0/22
15.230.56.104/31
35.180.0.0/16
```

The returned IP address ranges represent the entire IP address space used by the provider. Attackers may choose to limit their assessment to specific regions that they know are in use through reconnaissance analysis by adding a conditional operator to the JQ program:

```
$ wget -qO- https://ip-ranges.amazonaws.com/ip-ranges.json | jq '.prefixes[] | if .region == "us-east-1" then .ip_prefix else empty end' -r | head -3
15.230.56.104/31
52.93.127.163/32
3.2.0.0/24
```

Scanning Large Ranges: Masscan

Cloud Scanning

- Nmap is not ideal for scanning millions of IP addresses
- Masscan separates the SYN send from the ACK receive code
 - Sender can *fire-and-forget*
 - Receiver identifies open/closed from response
 - By decoupling the two halves of the three-way handshake, speed is greatly improved

```
$ masscan 192.168.1.1/24 -p 22,25,80,443,3389
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at
2021-08-06 11:02:56 GMT
```

NOTE

Masscan by Robert David Graham improved performance over early tools separating SYN send from ACK receive. With 20 Mbps bandwidth, Masscan can scan 16 million hosts for 10 ports each in about 1 hour.

Once an attacker identifies the range of IP addresses to scan, they can choose a tool to conduct the scan. We've already discussed Nmap, a powerful tool for scanning that has many different scan type and vulnerability assessment features as well. However, while Nmap is powerful, it is not adept at scanning large numbers of IP addresses. While Nmap can easily handle hundreds to even thousands of IP addresses in a scan, it will take a long time to complete a scan that covers really large network ranges, such as hundreds of thousands or even millions of hosts.

Masscan by Robert David Graham (<https://github.com/robertdavidgraham/masscan>) is a different type of a network scanning tool. Masscan does not have any near the amount of assessment functionality of Nmap, instead optimizing the design of Masscan to separate the *SYN send* code from the *ACK receive* code into different functionality. This allows Masscan to send TCP SYN packets at a very fast rate, since that part of the program is only concerned with sending packets. A receiving function is responsible for listening to any responses that would indicate if the port is open or closed. By decoupling the send from the receive functionality, Masscan can achieve much higher performance when testing for open ports.

Masscan's default is to send only 100 packets per second. This will still produce a fast scan result but does not show the true performance potential of the tool. At 50,000 packets per second (Masscan's `--rate 50000` option), Masscan will utilize about 20 Mbps of bandwidth. If you limit the target TCP ports to a list of 10 common ports, at 20 Mbps Masscan can scan 16 million IP addresses in about 1 hour.

```
$ wget -qO- https://ip-ranges.amazonaws.com/ip-ranges.json | jq '.prefixes[]
| if .region == "us-east-1" then .ip_prefix else empty end' -r | sort -u >
us-east-1-range.txt
$ masscan -iL us-east-1-range.txt -oL us-east-1-range.masscan -p 443
--rate 100000

Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2020-12-22 13:26:44 GMT
-- forced options: -sS -Pn -n --randomize-hosts -v --send-eth
Initiating SYN Stealth Scan
Scanning 32723888 hosts [1 port/host]
$ head -3 us-east-1-range.masscan
#masscan
open tcp 443 18.207.73.1 1608482904
open tcp 443 18.211.60.125 1608482904
$ awk '/open/ {print $4}' us-east-1-range.masscan > us-east-1-range.tlsopen
```

Using Masscan, it becomes possible to scan large ranges of IP addresses, including all the IP addresses for a given cloud provider with a well-connected system and hours to days to complete the scan accurately.

In the example on this page, we use Wget and JQ to retrieve a list of the AWS IP addresses associated with the us-east-1 region. The list of network numbers and CIDR masks is saved in the file `us-east-1-range.masscan`. Next, we scan the range of hosts reading the list of networks and CIDR masks with `-iL`, saving the scan results to a new file with `-oL`, and limiting the scan results to only TCP port 443 with `-p`. To conduct this scan, we used a well-connected AWS EC2 virtual machine in the same region as the target network, sending packets at a rate of 100,000 packets per second (PPS) with `--rate`.

At the time of this writing, the IP address list for the us-east-1 AWS region is about 32.7 million IP addresses. At a rate of 100,000 PPS and scanning for a single TCP port, this will take Masscan about 5.5 hours to complete the scan. Note that Masscan will lead to false-negatives if used too fast (e.g., PPS rate exceeds actual capacity for the host or the network). Adjusting the rate to 10,000 PPS will increase the time it takes to scan the range by a factor of 10 but improves positive identification rate of systems considerably.

When the scan completes, the output file logs open ports and the associated IP address followed by the epoch time for when Masscan identifies the port as open. We can use an Awk program to extract the IP address information, redirecting the output to a new file for our next step in the scanning process.

With a list of TLS servers, attribution is performed using certificate details

- Masscan reveals a list of IP addresses listening on TCP/443
- We can connect to the service and retrieve the certificate details
 - Reveals the certificate *common name* (CN) attribute, often identifying a target organization's domain name

```
$ head -1 us-east-1-range.tlsopen
18.207.73.1
$ openssl s_client -connect 18.207.73.1:443 2>/dev/null | openssl x509 -text
| grep Subject:
    Subject: C = US, ST = Florida, L = Miami, O = "e-Builder, Inc", OU =
Operations, CN = *.e-builder.net
```

The results of the Masscan analysis reveals a list of IP addresses listening on TCP port 443, but it does not provide any attribution for the customer using the cloud asset. To identify the cloud asset owner, we can connect to the open TCP port and retrieve certificate information from the server.

Since TCP/443 is a TLS-encrypted service, the server will disclose a server certificate to anyone that connects to the server. Under normal web browsing scenarios, this certificate is used to verify the identity of the organization hosting the service as part of the verification and encryption establishment process. Attackers can similarly leverage this information for attribution of the cloud virtual machine.

In the example on this page, we demonstrate the ability to identify the organization associated with the AWS cloud VM at 18.207.73.1 as the first IP address in the Masscan results. The command line tool openssl can connect to the server on the listening TCP port and extract certificate information using the `s_client` and `-connect` arguments as shown on this page. The output of the OpenSSL `s_client` command is a server certificate, which we pipe to the OpenSSL command again, this time decoding the X.509 certificate format into human-readable text. Sending the output of the `openssl x509` command to `grep` allows us to extract the subject line, disclosing the certificate country (C), state (ST), locality (L), organization (O), organizational unit (OU) and server common name (CN) as shown.

The OpenSSL utility can only connect to one server at a time. Fortunately, we can introduce another tool to accelerate the data collection process for us.

- TLS-Scan by Binu Ramakrishnan
 - Scans a list of TLS servers and collects certificate, cipher details
 - Fast, non-blocking, performant scanner
 - Saves results in JSON format

```
$ wget https://raw.githubusercontent.com/prbinu/tls-scan/master/ca-
bundle.crt
$ cat us-east-1-range.tlsopen | tls-scan --port=443 --cacert=ca-bundle.crt
-o us-east-1-range-tlsinfo.json
...
elapsed-time: 384 secs | status: 11886/11886 | tls-handshake: 11404 |
target: 54.147.226.48          pid: 29899 | ciphers: (0) | host-count: 11886
|elapsed-time: 384.750251 secs
```

TLS-Scan by Binu Ramakrishnan (<https://github.com/prbinu/tls-scan>) is a Linux and macOS tool that reads from a list of IP addresses, one per line, and extracts certificate information from the identified TLS server on a given port (here we use TCP port 443, but TLS-Scan can also extract TLS information from other ports as well such as TLS-enabled mail services).

For optimal performance with TLS-Scan, we supply the tool with a list of IP addresses that we know are listening on the given port (such as the scan results from Masscan conducted earlier in this module). First, we retrieve a list of trusted certificate authorities for TLS-Scan to use in verifying the certificates from the TLS-Scan project distribution page (on Slingshot Linux you can skip this step and reference the `ca-bundle.crt` file included at `/opt/tls-scan/ca-bundle.crt`).

TLS-Scan reads the list of IP addresses from standard input, retrieving the certificate details from each IP. We `cat` the list of IP addresses that are listening on TCP port 443 and pipe the list to `tls-scan`, specifying port 443, the CA certificate bundle, and the output file of certificate details to be saved in JSON format, as shown on this page.

TLS-Scan is fast and non-blocking (e.g., if a server is slow or not listening on the specified port, TLS-Scan will continue to collect information in other concurrent process threads) but will still require several minutes to collect certificate information from a large number of systems. TLS-Scan will display status information showing you the tool progress while it completes the scan.

```
$ cat us-east-1-range-tlsinfo.json | jq '[.ip,
.certificateChain[].subjectCN] | join(",")' -r > us-east-1-range-tlsinfo.csv
$ head -2 us-east-1-range-tlsinfo.csv
18.207.73.1,*.e-builder.net,Thawte RSA CA 2018
18.211.60.125,*.glanceqa.net,DigiCert SHA2 Secure Server CA,DigiCert Global
Root CA
$ grep "\.falsimentis\.com" us-east-1-range-tlsinfo.csv
54.83.227.100,*.falsimentis.com,DigiCert SHA2 Secure Server CA
54.211.2.148,*.qa.falsimentis.com,DigiCert SHA2 Secure Server CA
54.146.22.37,stark.api.qa.falsimentis.com,Amazon,Amazon Root CA 1,Starfield
Services Root Certificate Authority - G2
18.233.194.197,firmware-release.dev.falsimentis.com,Amazon,Amazon Root CA
1,Starfield Services Root Certificate Authority - G2
52.207.187.176,admin.dev.falsimentis.com,Amazon,Amazon Root CA 1,Starfield
Services Root Certificate Authority - G2
3.211.212.132,*.dev.falsimentis.com,DigiCert SHA2 Secure Server CA
```

TLS-Scan saves the scan results into a JSON-formatted file. We can use the JQ utility to extract the desired information from the scan, even formatting it in a CSV file for use with other tools.

In the example on this page, we use a short JQ program to access the TLS-Scan results in an array (the opening and closing square brackets `[]`), retrieving the `ip` field, and the `subjectCN` field within each of the `certificateChain` array results). These fields are piped within JQ to the `join()` function, using a comma delimiter to format the data as comma-separated values. To avoid extra quotation marks around each of the fields, we also add the JQ `-r` (raw) argument, then redirect the output to a CSV file.

The `certificateChain` array in the TLS-Scan results will identify the certificate identity for each certificate in the chain. There can be an arbitrary number of certificates in the `certificateChain`, but there will typically be at least two: the server certificate (e.g., the web server itself) and the certificate authority (CA) certificate. Searching for the domain name of our target with `grep` we see the identified CN for the certificates, revealing several IP addresses and complete or wildcard host names for the target organization's cloud servers, and the associated CA for the servers as well.

Another option to interpret the results of TLS-Scan output is the `extract-tlsscan-hostnames.py` Python script written by this author, available at <https://gist.github.com/joswrlght/1a4357330557ef16d3c8d4b57ec0db33> (<https://urls.sec504.org/jmlf4>).

Other Scanners: EyeWitness

Cloud Scanning

- Takes screenshots of websites, VNC and RDP services
- Can be very effective to sort through hundreds of different websites
- Attackers and testers look for default pages, out-of-date servers, RDP servers that show domains, indexed web directories, etc.
- Many vulnerabilities do not necessarily need an *exploit*
 - Finding backup files and install scripts on web servers can lead to easy access to external systems

TIP

Sometimes the results of a scan can be overwhelming.

EyeWitness by Chris Truncer makes it easy to grab a screenshot of web, VNC, and RDP services. Scan the results visually to look for interesting targets.

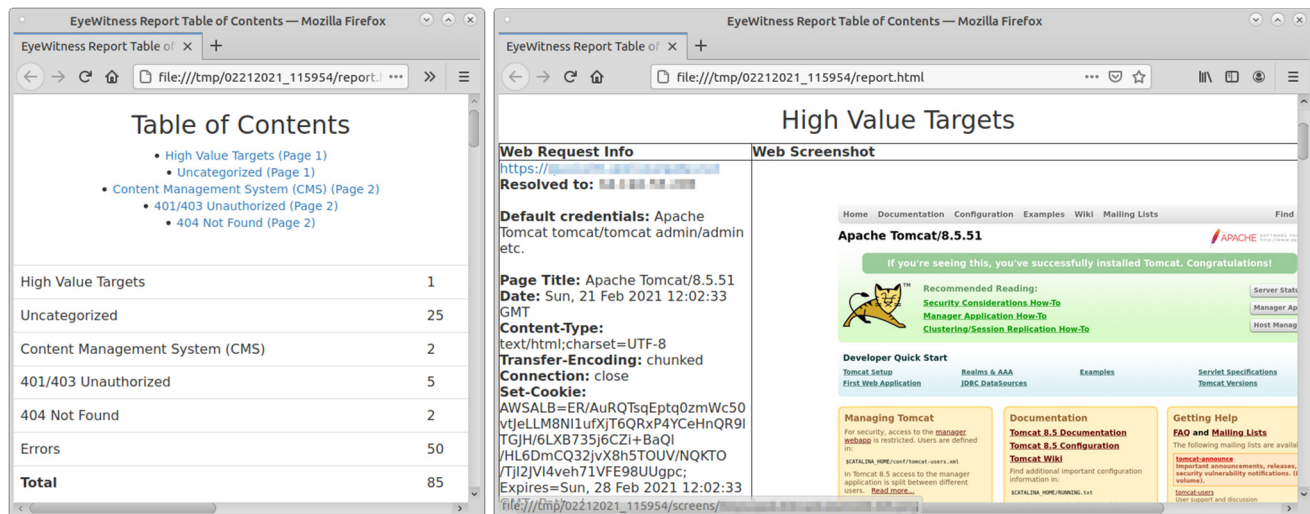
Using a combination of Masscan, TLS-Scan, JQ, and Grep, an attacker can scan the cloud network range and identify a list of servers listening on TCP/443 that belong to the target organization. If the organization is large with many servers, this can be a large list of targets. While a vulnerability scanning tool can be useful to scan and identify vulnerabilities for large numbers of systems, an attacker generally will want to narrow down the list of targets to identify systems that are likely to be useful in their attack.

Whether attacking cloud systems or internal servers within an organization, an attacker can use the EyeWitness by Chris Truncer (<https://github.com/FortyNorthSecurity/EyeWitness>) to quickly gather reconnaissance information. This tool will take a screenshot of every web server it detects to quickly identify the purpose of multiple websites simply by reviewing the pictures included in an HTML report.

EyeWitness will quickly identify default pages, management pages, and pages that return indexed directories of files at a quick glance. EyeWitness can also identify default credentials for some web applications and web servers. This can be valuable insight to an attacker as they refine the list of targets to systems that are likely to be useful in meeting their attack goals.

EyeWitness comes with a well-written usage guide. The guide and tool source code are available at <https://github.com/FortyNorthSecurity/EyeWitness>.

```
$ python3 /opt/eyewitness/EyeWitness.py --web -f urllist.txt --prepend-https
...
[*] Done! Report written in the /tmp/02212021_115954 folder!
Would you like to open the report now? [Y/n] Y
```



To use EyeWitness, you must supply one or more URLs. From the Masscan and TLS-Scan results where TCP/443 is open, we can build a list of IP addresses and host names of web servers to interrogate with EyeWitness.

While an attacker could just use a list of IP addresses with EyeWitness, this may not provide the most valuable results. Many web servers will respond with different content when visited by IP address compared to when the same server is visited by host name (as part of a virtual web host configuration). To get the best results, an attacker will visit the IP address of the server (https://10.10.10.10, for example), and any host name that is associated with the server.

In the TLS-Scan JSON results, an attacker can retrieve the IP address of the servers where TLS responds, as well as the Common Name (CN) and Subject Alt Name fields to identify the web server host name. The script `extract-tlsscan-hostnames` (<https://urls.sec504.org/lro6s>) reads from the TLS-Scan JSON file and extract as many host names as it can identify, one per line. Use this script with `grep` to build a list of the hosts extracted from the TLS-Scan results:

```
$ extract-tlsscan-hostnames us-east-1-range-tlsinfo.json | grep
"\.falsimentis\.com" | tee urllist.txt
act.falsimentis.com
box.falsimentis.com
dev.falsimentis.com
...
$ python3 /opt/eyewitness/EyeWitness.py --web -f urllist.txt --prepend-https
...
```

In the sample EyeWitness report shown on this page, EyeWitness has evaluated 85 targets and organized the web servers into different categories. Scrolling through the report reveals what the default page looks like on each server, including the Apache Tomcat server with default administrative credentials.

Cloud Scanning Defense

Cloud Scanning

- Most targets will not log half-open SYN scans (Nmap, Masscan)
- Many web servers will not log TLS-Scan access (since it lacks an HTTP request)
- As defenders we're interested in what happens *after* scanning
 - Web server logs reveal site crawling
 - Malformed requests or parameters sent to server-side code

We'll continue to investigate defenses to vulnerable systems

TIPS

In many cases, cloud systems do not need to be accessible by the entire internet. Limit access to WAFs, API consumers, and other required servers.

Ask *who* needs to connect to this server and apply firewall rules to restrict access.

In this module we looked at the steps that an attacker can use to perform scanning over thousands to millions of IP addresses to identify cloud systems associated with a target organization. From a defense perspective, it is difficult to log and capture this type of scanning since half-open SYN scans (used by Nmap and Masscan) are not logged by most target systems, and many web servers will not log TLS-Scan access (TLS-Scan terminates the connection after getting the certificate and before issuing an HTTP request). While it is possible to monitor scan behavior using packet capture tools, firewalls, or network flow analysis, it is difficult to identify any *malice* associated with scan behavior vs. normal server interaction.

One consideration for defenders when evaluating cloud security is to ask *what systems need to access this server?* If you are using a cloud web server, does the web server need to be publicly accessible to anyone, or can access be restricted with client-side firewall or Virtual Private Cloud (VPC) firewall controls? In many cases, API servers and web servers that are intended to be accessed only through a Web Application Firewall (WAF) do not need to be publicly accessible to other endpoints including attackers, and access can be restricted to a smaller pool of source IP addresses.

As defenders, we are primarily concerned with the activity that happens after scanning. This insight comes from web server logs that might reveal an attacker crawling all the pages on the server, or the presence of malformed requests or parameters sent to server-side code. As we continue with our look at attack techniques, we'll continue to investigate these attack signatures, and how we can best identify and defend both on-premises and cloud systems.

Cloud Spotlight Labs

Cloud Labs: Local for Perpetual Access, Reliability, Repeatability

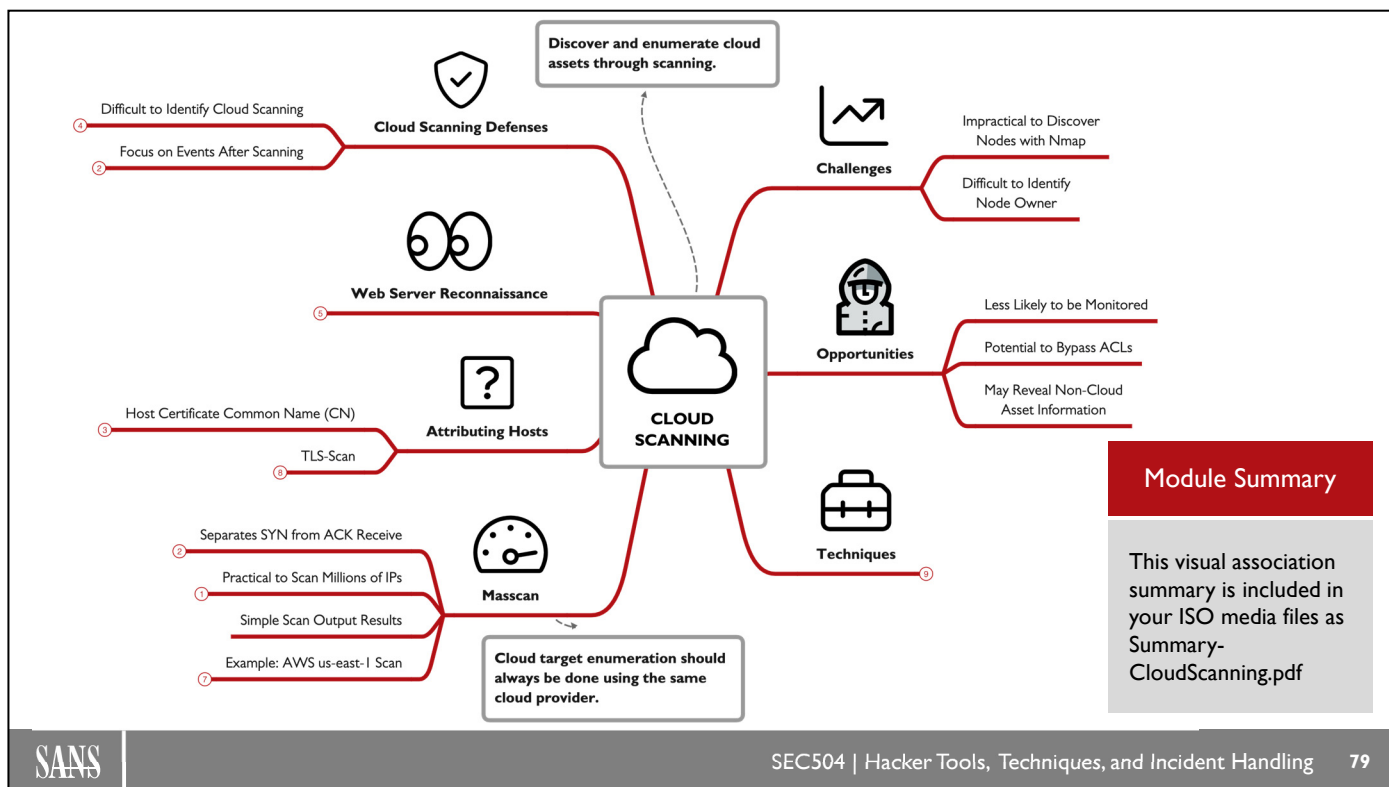
- We'll work on several labs using simulated cloud assets
- Labs are done locally and do not require internet access
 - You get perpetual access: *labs do not go away after N months*
 - You get reliability: *tested extensively on Slingshot*
 - You get repeatability: *easy to stop and restart the lab as often as you want*
- Code to produce Cloud Spotlight labs is included in `~/labs`
 - You can use this to deploy in actual cloud environments if desired
 - Deployment in an actual cloud provider is not supported by SANS

Before we start our first Cloud Spotlight lab exercise, a quick word on labs. As the author of SEC504, I chose to create the Cloud Spotlight lab exercises locally on the Slingshot Linux VM instead of relying on cloud providers such as Amazon AWS, Microsoft Azure, or Google Cloud Platform.

Using the simulated cloud environment, class participants get perpetual access to the labs (in actual cloud environments, access to the lab environment would necessarily be limited to a period of some months before losing access to the lab), reliability through extensive testing in Slingshot Linux (without the ever-changing cloud churn that causes many relied-upon APIs to break), and repeatability (complete the labs as many times as you want). While there is benefit from hands-on experience working with actual cloud providers, I felt the advantages of local lab access outweighed the benefits of working with actual cloud providers.

To make the local lab exercises feel more like working with actual cloud providers, we will simulate characteristics of actual cloud providers, often reusing DNS names or other API endpoints that are used by AWS, Azure, or GCP. This is not to deceive you into thinking you are working with actual cloud targets; it is only intended to make the labs feel more immersive and more closely match what you will do outside of a lab when working with actual cloud targets.

Finally, in any situation where custom code is necessary to create the environment for a lab exercise, I have included the code used for the lab and notes on how to deploy it in an actual cloud provider network. See the file `ACTUALCLOUD.md` in the directory for the target lab exercise for instructions on how to deploy the lab to an actual cloud provider using your own AWS credentials. Please note that SANS cannot provide support for deploying lab code in an actual cloud provider.



In this module we investigated the topics surrounding cloud scanning and enumeration. We started with a look at the challenges associated with enumerating cloud targets including the distributed nature of cloud IP address for a given target, the impracticality of scanning large ranges of IP addresses with Nmap, and the difficulty associated with identifying the owner of any given cloud node. However, an attacker also has several opportunities associated with cloud scanning, including the decreased likeliness that the scanning activity is being monitored, the potential to bypass network Access Control Lists (ACLs) when scanning from the same cloud provider, and the opportunity to identify even non-cloud asset information in the results of cloud target scanning and enumeration.

We looked at two techniques for scanning cloud assets, using sites including builtwith.com to identify which cloud provider is used for a target site, and the enumeration of widespread scanning of a target cloud provider network to identify attack targets.

Using a node in the same region as the target cloud environment, an attacker can leverage Masscan to scan large quantities of cloud IP addresses to identify active endpoints. Masscan is designed to perform scanning for a small number of ports across a large number of systems, well capable of scanning millions of target systems in a few hours from a well-connected system.

We looked at an example of using Masscan to scan an entire region of the AWS us-east-1 region, about 32.7 million IP addresses. Using a well-connected AWS EC2 instance in the same region, an attacker can scan for targets for a single TCP port at a rate of 100,000 packets per second, completing the scan in about 5.5 hours. After identifying the hosts listening on TCP port 443, an attacker can use TLS-Scan to collect certificate information from the hosts, extracting the details to a JSON file that can be interrogated to identify domain names for the target systems using JQ. This type of a scan may reveal multiple hosts. Attackers can automate the process of characterizing these hosts using EyeWitness, a tool that captures a screenshot for each web server in an HTML report.

Finally, we looked at defense options. Masscan generates few packets per host, and rarely generates host logging entries. TLS-Scan never sends an HTTP request, so it does not get logged by the web server. Instead of trying to capture and record this activity, we typically focus on the attacks that may happen after scanning.

LAB

Please work on the lab exercise
Cloud Scanning



Please work on the lab exercise *Cloud Scanning*. For this lab exercise you will need your class Slingshot Linux VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

...

DNS Interrogation

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

Lab: Cloud Scanning

SMB Security

Lab: SMB Security

Defense Spotlight: DeepBlueCLI

Lab: Windows Password Spray Attack Detection

An additional scanning technique lets an attacker grab data from a Windows environment across Server Message Block (SMB) sessions. This powerful technique allows an attacker to grab information about available users, groups, shares, and more, all by using a non-admin username and password. We look at a variety of tools to pull this information, especially SharpView for Windows and `rpcclient` for Linux. We also perform a hands-on lab to illustrate the technique.

SMB Security

- SMB is an application layer protocol that implements file and printer sharing, authentication, remote admin, and other features
- Why is SMB such a problem for modern networks?
 - Configuration is often done by end-users (creating shares, choosing files to place on shares, defining security for file access controls)
 - It is complex and has lots of legacy functionality to support
 - Lots of non-Windows devices use SMB with minimal implementations that don't support modern security features (printers, EKG machines ...)

SMB is heavily used by attackers, often appearing as "normal" TCP/445 traffic. It is an essential protocol to understand for defenders!

Microsoft created the Server Message Block (SMB) protocol to support a variety of network-accessible features of Windows systems, including file sharing, printer sharing, authentication, remote administration, and countless other capabilities. These features are used throughout most Windows deployments over TCP port 445. For many organizations, SMB access is normal on their networks, but it is also an opportunity for attackers to exploit systems while blending in to otherwise "normal" TCP/445 activity.

It's fair to ask why SMB is such a problem for modern networks. In most organizations, SMB services are often configured by end-users who can make file and printer shares on their workstations or copy files to a file server without caution in applying adequate access controls. Further, SMB is a complex protocol, and it has a lot of legacy functionality to support. Many of the SMB exploits we see target obscure features in the protocol that could have been written over 20 years ago, in a time when we did not have the same understanding and processes for the design and implementation of secure code. Finally, lots of non-Windows devices also support SMB, but with minimal implementations that don't support modern security features. Printers, network attached storage devices, even medical devices such as echocardiograms (elektrokardiogramms) can have SMB support to automate file transfer to a Windows server for subsequent access by a medical professional. These factors all contribute to a *reduction* in SMB security, since many organizations have to defend against attacks against the weakest SMB deployments.

In this module we'll dig into the SMB protocol and identify several techniques attackers use against Windows and non-Windows SMB implementations. We'll also investigate defense techniques you can apply in your organization to defend against common SMB attacks.

SMB protocol access is covered by several MITRE ATT&CK Framework categories including *Network Share Discovery* (T1135, <https://attack.mitre.org/techniques/T1135/>), *Windows Admin Shares* (T1077, <https://attack.mitre.org/techniques/T1077/>), and *Brute Force* (T1110, <https://attack.mitre.org/techniques/T1110/>).

SMB Security Features

SMB Security

	SMBv1	SMB v2.1	SMBv3	SMB v3.1.1
Minimum Workstation Version	XP	Win7	Win8	Win10
Minimum Server Version	Win2K3	Win2K8 R2	Win2K12	Win2K16
Encryption Support	No	No	Yes	Yes
Message Integrity/Signing	No	Yes, SHA256	Yes, AES-CMAC	Yes, AES-CMAC
MITM Resistant	No	No	Yes*	Yes
Pre-Auth Verification	No	No	No	Yes

NOTE

Many organizations continue to use old versions of SMB unnecessarily. This creates an opportunity for attackers to eavesdrop on SMB activity, to attack credentials, and to exploit vulnerable SMB implementations.

It's useful to understand the security features of the SMB protocol from early to current versions. From a security perspective, later versions of the SMB protocol (supported in later versions of Windows workstations and Windows servers) are preferred over older versions. Unfortunately, many organizations continue to use old versions of SMB, exposing the confidentiality and integrity of SMB data.

The chart on this page illustrates some of the newer features in later versions of SMB, and the required Windows workstation and Windows server versions required. At an absolute minimum, organizations should disable access to the SMBv1 protocol to take advantage of message integrity features added in SMB v2/v2.1. Windows has a built-in PowerShell command to disable SMBv1: `Disable-WindowsOptionalFeature -Online -FeatureName smb1protocol`.

Additional information on managing SMB versions in a Windows environment are available on the Microsoft website:

What's new in SMB 3.1.1 in the Windows Server 2016 Technical Preview 2: <https://docs.microsoft.com/en-us/archive/blogs/josebda/whats-new-in-smb-3-1-1-in-the-windows-server-2016-technical-preview-2>

How to enable and disable SMBv1, SMBv2, and SMBv3 in Windows and Windows Server: <https://docs.microsoft.com/en-us/windows-server/storage/file-server/troubleshoot/detect-enable-and-disable-smbv1-v2-v3>

* SMBv3 has defenses against MITM attacks but is only able to verify the presence of a MITM attacker after authentication is complete. This is addressed in SMB v3.1.1 where MITM defenses are verified before initial authentication.

```
PS C:\> Get-WmiObject -Class win32_share -ComputerName 192.168.171.155
```

Name	Path	Description
----	----	-----
ADMIN\$	C:\WINDOWS	Remote Admin
C\$	C:\	Default share
IPC\$		Remote IPC
Tools	C:\Tools	

Works for systems
implementing WMI
(Windows systems)

```
PS C:\> net.exe view \\192.168.1.73 /all
```

```
...
Share name  Type  Used as  Comment
-----
Documents  Disk           Documents
Pictures   Disk           Pictures
```

Works for Windows and
non-Windows systems

An SMB share is a resource where files can be read or written to or from an SMB server. SMB shares are often provisioned by an administrator as a collection of files for a specific department (*accountingfiles*) or a specific activity (*timesheets*) or even generic terms to give users the flexibility to decide how they want to store or access files (*companydata*). Windows servers or Windows workstations (Windows 10, Windows 11, etc.) can have SMB shares that allow access to other authenticated users, or to anyone without authentication as well. Attackers will often use compromised credentials to look for SMB on the inside of the network to gain access to this data, potentially as the goal of their attack, or as a mechanism to gather intelligence to apply to other attack techniques (such as collecting authentication credentials).

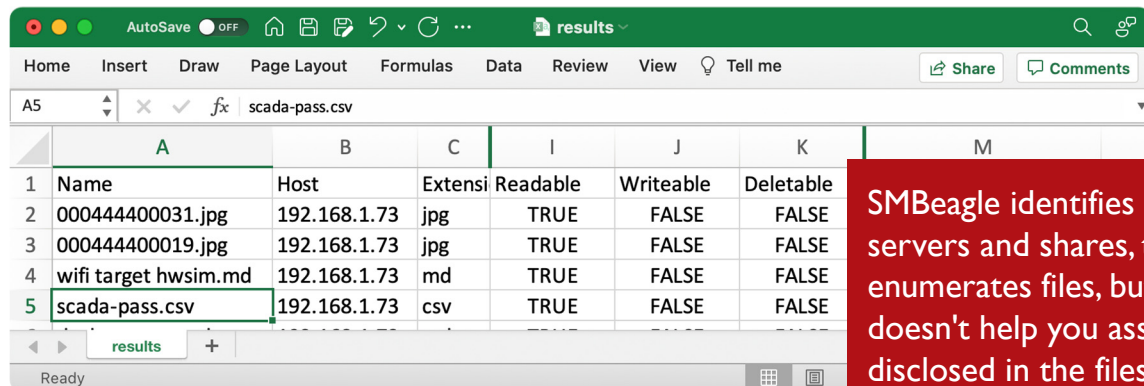
There are multiple ways for an attacker to enumerate servers with SMB shares. In PowerShell, one option is to use `Get-WmiObject -Class win32_share`, specifying a target `-ComputerName` by IP address or hostname. In the example on this page, the `Get-WmiObject` command returns a list of 4 shares: three end in a \$ to indicate an administrative share formerly this was called a *hidden share* but is not hidden at all), and one non-administrative share (*Tools*). In this example, `Get-WmiObject` is using the logged-in Windows credentials to access the share, though other credentials can be specified using the `-Credentials` option.

One significant limitation of share enumeration with `Get-WmiObject` is that it only enumerates the SMB shares for systems that fully implement the Windows Management Instrumentation (WMI) stack (e.g., this is mostly limited to Windows devices). SMB can be used on many other platforms as well, including Linux devices (through the Samba software) and embedded or IoT devices as well. To enumerate SMB shares on non-Windows devices, there are PowerShell add-in scripts (such as the `NetShareEnum` PowerShell function written by Will Schroeder/@harmj0y, available at <https://urls.sec504.org/zdq2p>), but we can also turn to the built-in `net.exe` utility, as shown on this page. For many situations, the `net.exe` utility is preferable for SMB share enumeration, since it will work with any SMB stack while still leveraging the logged-in credentials of the user to connect to the target system.

Searching for SMB Shares: SMBeagle

SMB Security

```
$ smbegoale -c results.csv -n 192.168.1.0/24 -u ksmith -p Password123 -q
SMBegoale by PunkSecurity [punksecurity.co.uk]
...
```



	A	B	C	I	J	K	M
1	Name	Host	Extensi	Readable	Writeable	Deletable	
2	000444400031.jpg	192.168.1.73	jpg	TRUE	FALSE	FALSE	
3	000444400019.jpg	192.168.1.73	jpg	TRUE	FALSE	FALSE	
4	wifi target hwsim.md	192.168.1.73	md	TRUE	FALSE	FALSE	
5	scada-pass.csv	192.168.1.73	csv	TRUE	FALSE	FALSE	

SMBeagle identifies SMB servers and shares, then enumerates files, but doesn't help you assess data disclosed in the files.

Instead of manually enumerating shares, attackers have many tools to discover SMB servers and accessible shares. In section 3 we'll investigate the Nmap tool as an option to perform this scanning, but there are also tools that specialize in SMB enumeration including SMBeagle by PunkSecurity (punksecurity.co.uk).

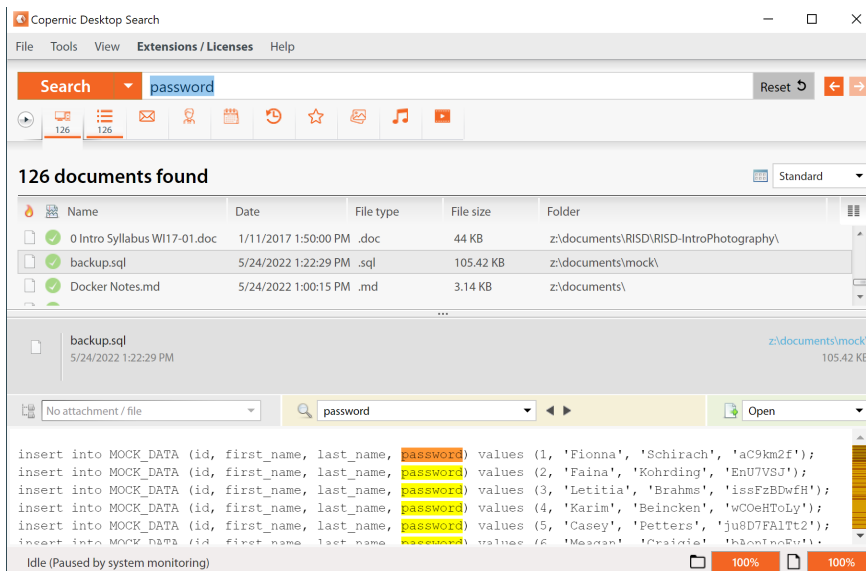
SMBeagle is a tool for Windows or Linux systems that will scan a range of hosts to identify SMB services using a specified username and password. For each identified share, SMBeagle will enumerate all accessible files on the server share, identifying if the file is readable, writable, or can be deleted with the specified privileges. SMBeagle saves the output in a CSV file, which can be imported as a spreadsheet for inspection, or further processed using PowerShell's `Import-Csv` command.

SMBeagle does a great job scanning for SMB servers and shares, and for enumerating files on the accessible shares, but it doesn't help with examining file content. You can use PowerShell or `grep` to search for strings that might indicate sensitive files (such as `scada-pass.csv` in the example on this page), but this is only surface-level analysis that doesn't take the content of files into consideration. For a more in-depth analysis for sensitive information disclosure, we need a different tool.

SMBeagle is available at <https://github.com/punk-security/SMBeagle>.

SMB Share Data Harvesting, Search

SMB Security



TIP

Copernic Desktop Search indexes file names and content for local files or SMB shares.

After building the index, you can quickly search for sensitive strings. Useful for defenders to audit server file shares!

To evaluate the data disclosed on an SMB share, we need a tool that not only enumerates file names, but also indexes the file content. There's several tools that can do this, but Copernic Desktop Search (<https://copernic.com/en/desktop/>) is a favorite among a lot of pen testers and defenders alike.

Copernic Desktop Search is commercial software (about \$55/year), designed to let users search files on their local drive or a networked share. It provides an easy interface to create an index of file names and content for lots of supported file types including compressed files, office documents, Optical Character Recognition (OCR) scanning of images, and more. Once the index is built, you can search through any number of files quickly for a string in the file name, or the file content.

In the example on this page we created a mapped drive letter Z : to a network share, then indexed all the files on this drive letter with Copernic Desktop Search. The indexing process takes some time depending on network performance and the number and size of files; in this example, 40 GB of files completed indexing in approximately 15 minutes. Once the indexing is complete, a search for a string such as *password* completes almost instantly, showing you the files that match the string in the file name, or the payload content. Here we see a file match called *backup.sql* which includes several password records for users (this is mock data generated for the example).

Copernic Desktop Search is not without its flaws. There is a bug in the software at the time of this writing where it can't identify partial string matches in the middle of a string if the string includes an underscore (it returns search results for the term *aws_access_key* but will not return the same matches if you search for a partial string such as *access_key*, for example). Copernic Desktop Search also doesn't index all files if it doesn't know how to process the filename extension. You can customize Copernic Desktop Search to index JSON, CSV, SQL, Markdown, and other file types in the settings, but by default it will skip over these files, a disappointing default.

To search for sensitive data in a file share, attackers will typically use the features of their Command & Control (C2) tools or PowerShell scripts to look for embedded strings. For defenders though, Copernic Desktop Search is a much better interface, capable of extracting, indexing, and searching a vast amount of file data for content that may be a risk for unauthorized information disclosure.

SMB Access: The Linux Way

SMB Security

```
$ smbclient -L //192.168.99.10 -U ksmith -m SMB2
```

```
Enter ksmith's password:
```

Sharename	Type	Comment
-----	----	-----
accounting\$	Disk	
acctpriv\$	Disk	
C\$	Disk	Default share

Enter the user's password when prompted. -L lists the available shares.

```
$ smbclient //192.168.99.10/accounting$ -U ksmith -m SMB2
```

```
Enter ksmith's password:
```

```
smb: \> ls
```

```
billable.xlsx
```

```
smb: \> get billable.xlsx
```

```
getting file \billable.xlsx of size 46884 as billable.xlsx
```

Connect to the specified share. List files with `ls`, retrieve files with `get filename`

In addition to using a Windows 10 system to attack a Windows server, we can also attack Windows systems from Linux and UNIX systems. The `smbclient` program that is part of the Samba suite can get a list of shares from a target Windows box with the `-L` argument, as shown in the first example on this page. Note that here we have specified the maximum SMB protocol version of SMB2, which is sometimes required to connect to a Windows 2019 server or later from a Linux or UNIX system (in general, leave this parameter off unless you get a protocol negotiation failed: `NT_STATUS_CONNECTION_RESET` error message).

Alternatively, you can use `smbclient` to make an *interactive* SMB connection to a target Windows system and then push (upload) or pull (download) files from the target. When connecting to an SMB share, this `smbclient` tool provides an interactive command prompt that is reminiscent of an FTP client, letting you navigate the directory structure with `cd`, get a directory listing with `ls`, and pull files with the `get` command, as shown on this page.

Using Samba's rpcclient from Linux for More Info

SMB Security

```
$ rpcclient -U ksmith 192.168.99.10
Enter ksmith's password:
rpcclient $> enumdomusers
user:[Administrator] rid:[0x1f4]
user:[krbtgt] rid:[0x1f6]
user:[ksmith] rid:[0x3e8]
user:[dwilliams] rid:[0x3ea]
user:[edavis] rid:[0x3ed]
rpcclient $> srvinfo
      192.168.99.10  Wk Sv PDC Tim NT
platform_id       :500
os version        :10.0
server type       :0x80102b
rpcclient $> enumalsgroups domain
group:[Cert Publishers] rid:[0x205]
...
```

Command	Function
enumdomusers	List users
enumalsgroups domain builtin	List groups (<i>enum</i> <i>alias</i> group)
lsaenumsid	Show all users SIDs defined on the box
lookupnames name	Show SID associated with user or group name
lookupsids sid	Show username associated with SID
srvinfo	Show OS type and version

The biggest treasure trove of information you can get via SMB sessions is available via a Linux tool called `rpcclient`. Originally created as a troubleshooting and debugging tool for the Samba suite, `rpcclient` is very flexible and includes hundreds of features. To establish an SMB session with `rpcclient`, you first run:

```
$ rpcclient -U username server
```

After you provide a password, you receive the `rpcclient` prompt:

```
rpcclient $>
```

At this prompt, you can type any one of more than 100 commands. Some of the most useful are:

- **enumdomusers**: This command shows users defined locally on the machine and any domain users the system knows about
- **enumalsgroups**: This command, followed by the word `domain` or `builtin`, shows groups defined on the box. The *als* in the middle of *enum* and *groups* in this command's name refers to the word *alias*
- **lsaenumsid**: This command shows the Security Identifier (SID) of all users defined locally on the target Windows system
- **lookupnames**: This feature lets you see the SID for a username that you provide
- **lookupsids**: This feature converts a SID you provide into the username on the target system
- **srvinfo**: Shows the version of the target Windows machine

We have included a cheat sheet for `rpcclient` with your class media files in the `CheatSheets` directory named `SMB Access from Linux.pdf` which shows several examples of useful `rpcclient` commands for SMB interrogation.

SMB Exploits

- SMB is a complex protocol that has been around for a long time
- Organizations mitigate SMB flaws with regular patching
 - Many organizations have SMB servers that don't get patched regularly
 - Attackers exploit these systems first, then pivot to other targets

SMB Security

CVE	Notes
CVE-2022-24500	RCE exploit published, pulled from GitHub
CVE-2021-36972	Unauthenticated information disclosure
CVE-2020-1206	SMBleed, limited Win10 version applicability
CVE-2020-0796	SMBGhost/CoronaBlue, widespread use
CVE-2017-0144	EternalBlue, WannaCry ransomware

We'll investigate Windows SMB remote code execution attack opportunities in section 4.

According to the NIST National Vulnerability Database (<https://nvd.nist.gov>), Microsoft discloses about 6 vulnerabilities per year in the Windows SMB stack (<https://urls.sec504.org/yr58>). Not all of these are high-risk threats that turn into widely-exploited Remote Code Execution vulnerabilities with public exploits, but many are, with memorable exploit names: SMBleed, SMBGhost, EternalBlue, etc.

The earliest implementation of SMB is from 1983, though much of what we think of today as SMB came out with Windows 2000. As we saw earlier in this module, Microsoft continues to improve the security of the SMB software but doesn't regularly remove legacy functionality since that could break customer use cases (it wasn't until Windows Server 2016 that Microsoft turned SMB 1.0 off by default, for example, and even then, only for new Windows Server 2016 installs, not upgrades). As a result, even modern Windows systems support a lot of legacy SMB functionality, including code likely written over a decade ago when Software Development Lifecycle (SDL) practices were not as vigorous as they are today.

If you are involved with patching Windows systems, then this is not a surprise to you. Throughout the year, Microsoft will advise customers to quickly deploy patches to resolve high-risk threats in SMB. Organizations that have well-designed procedures for maintaining software deploy these patches quickly and take advantage of the protection Microsoft offers through hotfixes. Yet many organizations, even with sophisticated patch management tools, have some Windows systems that don't get patched regularly. Maybe there are exceptions to patch management practices for specific systems because of critical software compatibility concerns, or systems that are not part of the patch management process such as embedded hosts that control digital displays for a restaurant menu or an airport flight status display. These are the systems that attackers will often target first, using well-known vulnerabilities to gain unauthorized access, then using that access to pivot to other targets in the organization.

```
PS C:\> $user = 'ksmith'
PS C:\> $pass = 'Password123'
PS C:\> New-SmbMapping -LocalPath Y: -RemotePath \\192.168.1.73\files
-UserName $user -Password $pass
```

Status	Local Path	Remote Path
OK	Y:	\\192.168.1.73\files

```
PS C:\tools> Import-Module .\LocalPasswordSpray.ps1
PS C:\tools> Invoke-LocalPasswordSpray -Password Password123
...
[*] SUCCESS! User:ksmith Password:Password123
```

We'll investigate more flexible remote SMB password attacks in section 3.

Even without a specific, unpatched SMB vulnerability, attackers can exploit SMB to gain unauthorized access to files or even the ability to run commands on a remote system. Windows SMB implementations do not implement a back-off delay for password guessing (though Microsoft has announced a future change to Windows 11 and Windows 2022 systems; more information is available at <https://urls.sec504.org/dn14z>), making it possible for an attacker to quickly guess passwords until they find a valid username and password combination. Microsoft does offer other countermeasures against these password guessing attacks, including account lockout, but attackers have found ways to evade these controls as well. We'll spend more time investigating these controls and evasion tactics in our section 3 course materials.

In the first example on this page, we use PowerShell to call `New-SmbMapping`, connecting to the RemotePath SMB server and share at `\\192.168.1.73\files`, mapping the share as the drive letter X. If authentication is successful, PowerShell will add the drive letter to the local system, telling the attacker that the credentials specified are valid. An attacker could extend this PowerShell command to use a list of usernames and/or a list of passwords to try and authenticate to one or more servers until they identify a valid username and password combination.

It's important to note that the password attack using `New-SmbMapping` can be remote or local. This attack could be done by an attacker from their Windows system, or from a compromised Windows system inside the network, against an SMB target. It could also be used against the local system (where 192.168.1.73 is the same Windows system where the attacker launches PowerShell) to test other local user accounts to gain access to other resources on the system.

These attacks are also implemented using third-party PowerShell scripts, which makes the attack process easier. `LocalPasswordSpray.ps1` is a PowerShell script by Beau Bullock (@dafthack) included in your Windows VM that automates the process of password guessing against the local system. We'll use the `Invoke-LocalPasswordSpray` attack in our lab exercise for this module. Bullock has also published `DomainPasswordSpray` (<https://github.com/dafthack/DomainPasswordSpray>) which uses similar syntax to attack Windows domain passwords.

In many ways, the SMB protocol password authentication process has not evolved to match advancements in security seen in other protocols. It continues to be a weak point for many organizations, creating opportunity for an attacker.


```
PS C:\> Get-SmbSession
SessionId      ClientComputerName ClientUserName      NumOpens
-----
549755813893 10.10.75.1          SEC504STUDENT\sec504 1

PS C:\> Get-SmbSession | Select-Object ClientComputerName, Dialect,
SecondsExists, SecondsIdle
ClientComputerName Dialect SecondsExists SecondsIdle
-----
10.10.75.1         3.1.1          8147           84

PS C:\> $Password = Read-Host -AsSecureString
*****
PS C:\> Set-LocalUser -Name sec504 -Password $Password
PS C:\> Close-SmbSession -ClientComputerName 10.10.75.1 -Force
```

As a defender, it is important to understand the techniques to enumerate and terminate unauthorized SMB connections. You can use the PowerShell command `Get-SmbSession` to enumerate all SMB connections to the local SMB server. In the example on this page, `Get-SmbSession` reveals an active client session from 10.10.75.1 with 1 open connection. You can also retrieve additional properties from the output of `Get-SmbSession`, including the SMB version in use, the number of seconds elapsed for the connection, and the number of seconds since the last SMB request (the idle time).

Before disconnecting the session, you will likely want to change the password for the identified user account. If you disconnect the session without changing the password, an attacker can reestablish their connection immediately after termination. In the example on this page we generate a PowerShell `System.Security.SecureString` object for the password using `Read-Host -AsSecureString`. After creating the secure string object, we can change the password for the user with `Set-LocalUser` (for a domain user account use `Set-ADAccountPassword`). Next, we use `Set-LocalUser` to reset the password for the sec504 account identified in the output of `Get-SmbSession`. Finally, we then close the sec504 account session using `Close-SmbSession`.

Functionality	PowerShell	CMD Command
View Remote SMB shares	<code>Get-WmiObject -Class win32_share -ComputerName <i>serverip</i></code>	<code>net view /all \\server</code>
View Local SMB Shares	<code>Get-SMBShare</code>	<code>net share</code>
Connect SMB share	<code>New-SmbMapping -LocalPath X: -RemotePath \\server\sharename</code>	<code>net use \\server\sharename</code>
View Inbound Connections	<code>Get-SmbSession</code>	<code>net session</code>
Drop Inbound Connections	<code>Close-SmbSession</code>	<code>net session \\server /del</code>
View Outbound SMB Mapped Connections	<code>Get-SmbMapping</code>	<code>net use</code>
Drop Outbound SMB Mapped Connections	<code>Remove-SmbMapping -Force</code>	<code>net use * /del</code>

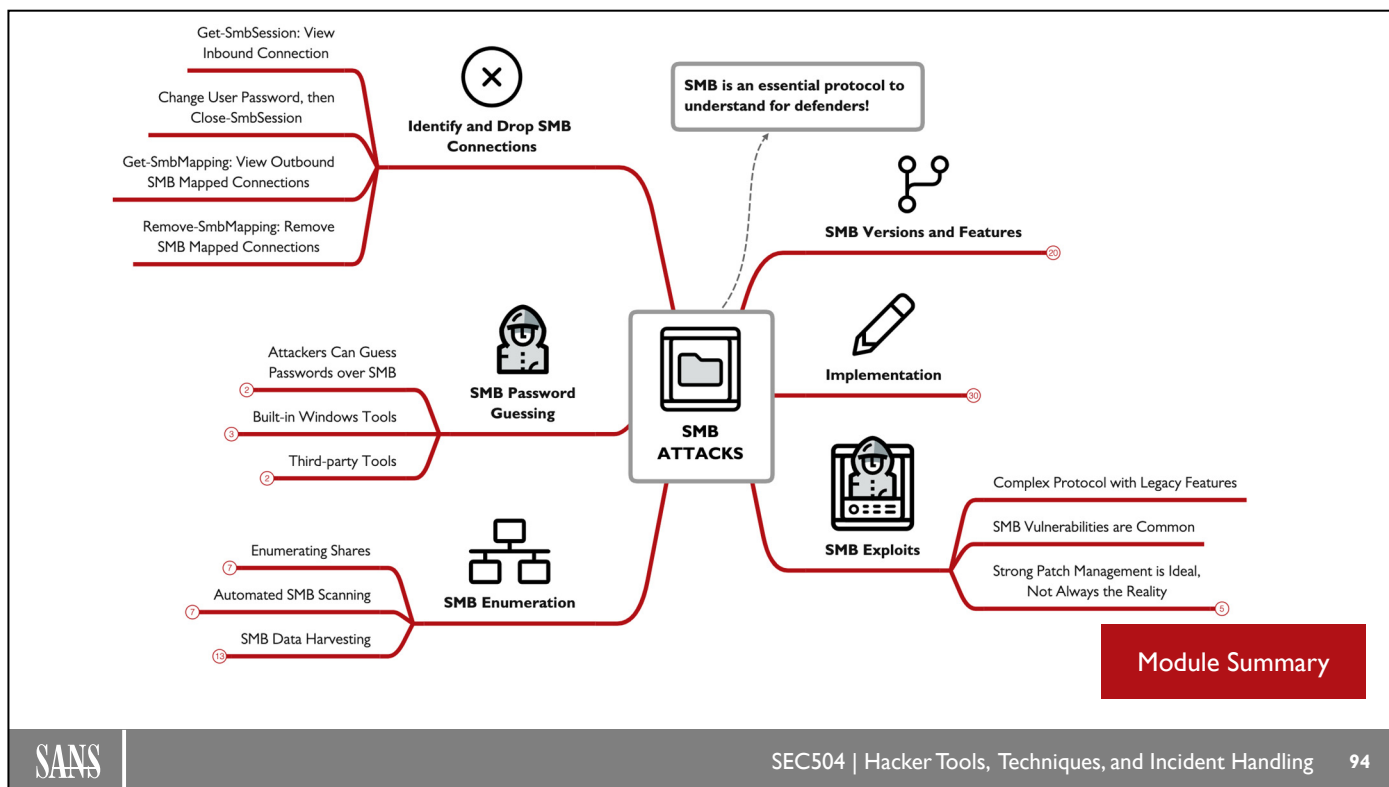
In this module we focused on PowerShell commands to interact with SMB, but there are several CMD functions available as well, primarily through the `net.exe` utility. We've identified the comparable `net.exe` command functionality next to each PowerShell command on this page for easy reference.

NOTE: The parameter *server* in these examples can be an SMB server IP address or hostname. Replace the value *server* with your SMB server IP address or hostname. Similarly, replace *sharename* with the target SMB server share name.

- Block access to the following ports across network boundaries and local firewalls:
 - TCP/445, UDP/445, TCP/135, TCP/137, UDP/137, UDP/138, TCP/139
 - In general, *block all ports except those required*
- Alternative: explicitly permit these ports only from systems or networks that require SMB access to a specified destination
 - Such as file servers and domain controllers
- Private VLANs are useful to limit inter-workstation access
- Check for access to the ports listed above in logs

Typically, you need to allow SMB sessions only from clients to a specific set of servers (such as file servers and domain controllers). Usually, you don't need clients to establish SMB sessions to other clients. Thus, you can implement some solid defenses by configuring routers and firewalls to block SMB sessions with TCP port 445, as well as the NetBIOS ports TCP and UDP 135 through 139. Allow such traffic only to specific systems where there is a business need for SMB.

Some organizations deploy client systems on Private VLANs (PVLANS), a switch feature that provides them a major degree of control over what goes into and out of the network interface connecting to each individual host. With PVLANS, you could block all inbound SMB to client machines and allow outbound SMB only to specific servers.



This visual association summary is included in your ISO media files as Summary-SMBAttacks.pdf

In this module we looked at the ubiquitous SMB protocol used in Windows networks. SMB is a common target for attackers and is essential for defenders to understand as well.

We looked at the different versions of the SMB protocol, presenting the different SMB security features and required client and server versions to utilize them. Ideally organizations should use the latest SMB version available (3.1.1 at the time of this writing; enforced with group policy controls), provided all server and workstation versions meet the minimum requirements for this version of SMB. Few organizations can take advantage of the most recent version of SMB however, often from the need to maintain legacy SMB device support.

Windows SMB services use the Windows Server service for server-side functionality, and the Windows Workstation service for client-side functionality. Both services run on Windows workstations and servers. Linux systems use the SAMBA software to serve and interact with SMB services. In this module we looked at both implementations, focusing on PowerShell and CMD commands on Windows systems, and the `smbclient` and `rpcclient` commands for Linux.

We looked at the topic of SMB exploits, and how SMB systems are commonly exposed to attacks from public SMB vulnerabilities. Strong patch management systems can help update software to limit the opportunity for an attacker to exploit these vulnerabilities, but this not always the reality for many organizations. It's common to see Windows systems that are behind on patches, which creates an opportunity for the attacker.

We looked at different techniques to enumerate SMB devices including hosts with SMB service, enumerating shares on those systems, and enumerating files and content on the shares. Nmap can be used to identify systems running SMB and enumerate SMB shares using the Nmap Scripting Engine (NSE) scripts. Tools like SMBBeagle are purpose-built for scanning networks for SMB services, enumerating shares and files and exporting the data to a CSV file for inspection. While these tools are useful for enumerating SMB servers, shares, and files, they don't help to evaluate SMB content. To evaluate SMB content, we can use tools designed for indexing file content for

quick search including Copernic Desktop Search.

We looked at different techniques an attacker can use for password attacks against an SMB server. Windows server and workstation systems don't yet implement a delay following a failed authentication request, making SMB a common target for password attacks. We looked at the `New-SmbSession` command and how it can be used to implement a password guessing attack, either locally against a compromised Windows system, or against another Windows system on the network. We also looked at the `LocalPasswordSpray.ps1` script as a mechanism to automate a password spray attack against a local Windows system (more on password spray attacks in our section 3 material).

From a defense perspective, it's helpful to inspect the status of current SMB sessions. We looked at several commands to enumerate inbound or outbound SMB connections, and how to terminate SMB activity that is not wanted. We can also block SMB access using firewall rules on the host or network devices using the documented SMB ports over TCP and UDP protocols.

LAB

Please work on the lab exercise
SMB Security



Please work on the lab exercise *SMB Security*. For this lab exercise you will need your class Slingshot Linux VM and the class Windows VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasion and Post-Exploitation Attacks
- Hands-on CTF Event

Recon, Scanning, Enumeration

...

DNS Interrogation

Lab: DNS Interrogation

Website Reconnaissance

Network and Host Scanning with Nmap

Lab: Nmap

Cloud Spotlight: Cloud Scanning

Lab: Cloud Scanning

SMB Security

Lab: SMB Security

[Defense Spotlight: DeepBlueCLI](#)

Lab: Windows Password Spray Attack Detection

Next, we'll turn to our first Defense Spotlight section: Examining the DeepBlueCLI tool as a mechanism to detect many attacks against Windows systems using standard logging facilities.

Defense Spotlight: DeepBlueCLI

- DeepBlueCLI is a PowerShell script that parses Windows event logs
 - Searches for unusual behavior or characteristics
 - Generates straightforward output characterizing the EOI

```
PS C:\> Get-Service | FL -property Name
...
Name : BITS
Name : TrustedInstaller
Name : gybHFpxOEvZDJSjz
Name : XboxNetApiSvc
```

Consider the output from PowerShell's `Get-Service`. Two services have 16-character service names consisting of lowercase and uppercase letters. One is malicious.

DeepBlueCLI aims to provide *useful* analysis, not *perfect* analysis.

DeepBlueCLI is a PowerShell script written by Eric Conrad (https://twitter.com/eric_conrad) that parses Windows event log data. DeepBlueCLI uses the standard event logging data to identify unusual behavior or characteristics of an attack, generating a report to characterize and identify Events of Interest (EOIs).

For example, consider the behavior of Metasploit's PsExec exploit against a Windows target. Metasploit will create a temporary Windows service, identifying the service with a name of 16 characters consisting of uppercase and lowercase letters.

In the output of the PowerShell `Get-Service | Format-List -property Name` command shown on this page (shortened on this page for space), we see four services, two of which have 16-character service names matching the pattern used by Metasploit. DeepBlueCLI will characterize the presence of the random-looking service name, disregard the known good service name (TrustedInstaller) and raise an alert, indicating a potential attack.

DeepBlueCLI can make mistakes. For example, it's entirely possible that DeepBlueCLI mischaracterizes a legitimate service name matching the Metasploit naming convention as an attack. Or DeepBlueCLI may mischaracterize a legitimate Metasploit attack as a normal service.

DeepBlueCLI aims to provide *useful* analysis, not *perfect* analysis. As such, it is a tool that should be used by an analyst as one input among many to characterize an attack, yet it remains a valuable tool altogether.

- Can detect multiple attacks
 - Several Metasploit exploits, Mimikatz, PowerShell Empire, password guessing, password spray, and more
 - Won't detect each tool every time, but will detect *many* attacks
- Use on a local system, over the Windows domain network, or on offline log files

```
PS C:\> DeepBlue.ps1
PS C:\> DeepBlue.ps1 Logfile.evtx
PS C:\> DeepBlue.ps1 -Log System
PS C:\> $credential = Get-Credential
PS C:\> DeepBlue.ps1 -Log System -Hostname DC1 -Credential $credential
```

DeepBlueCLI does not require any special configuration and relies primarily on the default logging services on Windows 10 and Windows server systems. Using just the standard logging facilities available in Event Viewer, DeepBlueCLI can detect multiple attacks including several Metasploit exploits, Mimikatz, PowerShell Empire, password guessing, password spray, and more. DeepBlueCLI won't detect each tool for every use case, but it will detect many attacks without any special configuration on the Windows target.

DeepBlueCLI can read Windows event logs from the local system (from a named file, or by specifying the logging source name, e.g., System, Security, etc.), on a remote system over the Windows domain network, or on offline log files, as shown in the examples on this page.

```
PS C:\dev\DeepBlueCLI> .\DeepBlue.ps1 .\evtx\password-spray.evtx
```

```
Date      : 4/30/2019 3:27:40 PM
```

```
Log       : Security
```

```
EventID   : 4648
```

```
Message  : Distributed Account Explicit Credential Use (Password Spray Attack)
```

```
Results  : The use of multiple user account access attempts with explicit credentials is an indicator of a password spray attack.
```

```
Target Usernames: gsalinas cdavis lpesce Administrator melliott dpendolino cragoso baker cmoody rbowen
```

```
jkulikowski jleytevidal tbennett zmat
```

```
wstrzelec drook dmashburn sanson cflee
```

```
celgee bhostetler eskoudis kperryman
```

```
ssims psmith jorchilles smisenar lscha
```

```
bking mdouglas jlake jwright econrad
```

```
Accessing Username: jwrig
```

```
Accessing Host Name: DESKTOP-JR78RLP
```

DeepBlueCLI characterizes a password spray attack by looking at multiple authentication attempts using explicit credentials.

In the example shown on this page, we have used DeepBlueCLI with a saved Windows event log (.evtx) file. By specifying the file as the command-line argument, DeepBlueCLI characterizes the logging data and identifies an event *Distributed Account Explicit Credential Use (Password Spray Attack)*, denoting the target usernames that were targeted by an attacker, the username of the logged-in account that mounted the attack (jwrig), and the attacking host name (DESKTOP-JR78RLP).

DeepBlueCLI Metasploit Attack Detection

DeepBlueCLI

```
PS C:\dev\DeepBlueCLI> .\DeepBlue.ps1 .\evtx\metasploit-psexec-native-  
target-security.evtx
```

```
Date      : 9/20/2019 11:41:13 PM  
Log       : Security  
EventID   : 4688  
Message   : Suspicious Command Line  
Results    : Metasploit-style cmd with pipe (possible use of Meterpreter  
'getsystem')  
  
Command   : cmd.exe /c echo hgabms > \\.pipe\hgabms  
Decoded    :
```

DeepBlueCLI can identify characteristics of some specific attack tools

In another example, DeepBlueCLI identifies the use of a Metasploit-style command using a named pipe (also characterized by the Meterpreter `getsystem` command).

DeepBlueCLI Non-Malicious Event

DeepBlueCLI

```
PS C:\dev\DeepBlueCLI> .\DeepBlue.ps1 -Log System

Date      : 8/18/2020 7:59:33 PM
Log       : System
EventID   : 7036
Message   : Suspicious Service Name
Results   : Service name: AvastTaskUpdater
           Metasploit-style service name: 16 characters

Command   :
Decoded    :
```

DeepBlueCLI will also alert on potentially non-malicious activity. It is up to you as the analyst to interpret the DeepBlueCLI analysis based on your system knowledge.

Here we demonstrate the use of DeepBlueCLI on a local system, evaluating the local System log resource (running DeepBlueCLI with no arguments will read from the local Security log).

Here DeepBlueCLI has characterized an event where a service name that consists of exactly 16 characters is present. This is most likely a false positive, though it should be verified on the local system. It is up to you as the analyst to interpret the DeepBlueCLI analysis based on your system knowledge.

DeepBlueCLI can take advantage of other PowerShell cmdlets

```
PS C:\dev\DeepBlueCLI> .\DeepBlue.ps1 Security.evtx | Format-List -Property  
Message, Results
```

```
Message : Suspicious Command Line
```

```
Results : Possible command obfuscation: only 60% alphanumeric and common  
symbols
```

```
Message : Suspicious Command Line
```

```
Results : Long Command Line: greater than 1000 bytes
```

```
Possible command obfuscation: 75% zeroes and ones
```

```
PS C:\dev\DeepBlueCLI> .\DeepBlue.ps1 Security.evtx | Export-Csv -Path  
Report.csv
```

As a PowerShell cmdlet, DeepBlueCLI can take advantage of other PowerShell pipeline filters. In the first example shown on this page, we have piped the output of DeepBlueCLI's report to the Format-List modifier, limiting the output to the Message and Result fields. You can also export the DeepBlueCLI analysis to CSV, JSON, XML, HTML, and TXT formats, or display the output in a GUI table view (DeepBlueCLI | Out-GridView) as desired.

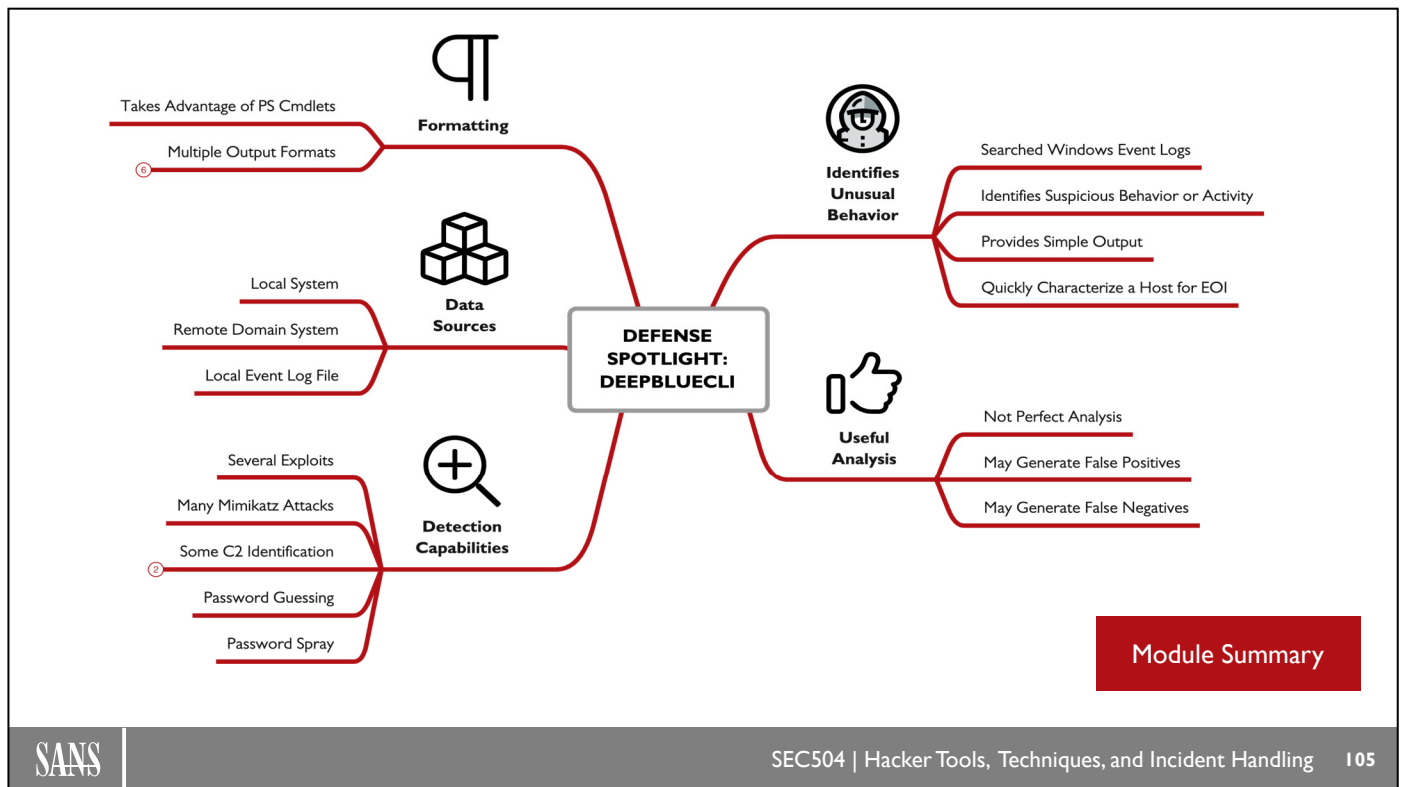
Conclusion

DeepBlueCLI

- DeepBlueCLI is a useful tool for quickly assessing Windows event logs
 - Read from local files on the file system
 - Read from local event logs by log name
 - Read from remote event logs in a Windows domain
- DeepBlueCLI does not provide perfect analysis
 - But it does catch many different attacks common to known attacker TTPs
- You as the analyst must judge the output with other known criteria to evaluate DeepBlueCLI's output

DeepBlueCLI is a useful tool for quickly assessing Windows event logs, without any prior setup needed to characterize several different attacks. Using DeepBlueCLI, an analyst can evaluate local logging files by name, local event logs by the log name, or remote event logs in a Windows domain.

DeepBlueCLI does not claim to provide perfect analysis, but it does catch many different attacks common to known attacker TTPs. As a straightforward tool, it can provide valuable insight into events of interest on a Windows system that will form part of the total information set available to the analyst.



This visual association summary is included in your ISO media files as Summary-DeepBlueCLI.pdf

In this module we investigated the topics surrounding the defense spotlight tool DeepBlueCLI. DeepBlueCLI is a PowerShell script that uses Windows event log information to identify suspicious behavior and events of interest (EOI) that can be investigated further. DeepBlueCLI aims to provide *useful* analysis results, quickly and easily, but it does not claim to provide *perfect* analysis results. Indeed, while DeepBlueCLI can be useful to quickly identify suspicious behavior or activity on a system, it can also generate false positives or false negatives as well.

DeepBlueCLI includes support to identify many attacks against a Windows system including several well-known exploits, many Mimikatz attacks, Command and Control (C2) activity from Metasploit Meterpreter and PowerShell Empire, as well as password guessing and password spray attacks. DeepBlueCLI can read from event logs on the local system, against a remote system on the domain, or a local copy of event log file.

DeepBlueCLI's output is straightforward text, but it can take advantage of several output formatting mechanism available to PowerShell scripts including CSV (ConvertTo-Csv), JSON (ConvertTo-JSON), HTML (ConvertTo-HTML) and more. DeepBlueCLI is also compatible with the PowerShell Out-GridView cmdlet, which allows you to inspect the assessment results using a tabular, graphical interface.

LAB

Please work on the lab exercise
*Windows Password Spray Attack
Detection*



Please work on the lab exercise *Windows Password Spray Attack Detection*. For this lab exercise you will need your class Windows VM.

Course Resources and Contact Information



AUTHOR CONTACT

Joshua Wright
jwright@willhackforsushi.com
Twitter: @joswr1ght



SANS INSTITUTE

11200 Rockville Pike, Suite 200
North Bethesda, MD 20852
301.654.SANS(7267)



PEN TESTING RESOURCES

pen-testing.sans.org
Twitter: @SANSPenTest



SANS EMAIL

GENERAL INQUIRIES: info@sans.org
REGISTRATION: registration@sans.org
TUITION: tuition@sans.org
PRESS/PR: press@sans.org

This page intentionally left blank.

SANS CURRICULUM FOCUS AREA

DIGITAL FORENSICS & INCIDENT RESPONSE (DFIR) AND THREAT HUNTING

Organizations of all sizes need personnel who can master incident response techniques to properly identify compromised systems, provide effective containment of the breach, and rapidly remediate the incident.

Similarly, government and law enforcement agencies require skilled personnel to perform media exploitation and recover key evidence from adversary systems and devices. SANS Incident Response, Threat Hunting and Digital Forensics will teach you to:

- Hunt for the adversary before and during an incident across your enterprise
- Acquire in-depth digital forensics knowledge of Microsoft Windows and Apple OSX operating systems
- Examine portable smartphone and mobile devices to look for malware and digital forensic artifacts
- Incorporate network forensics into your investigations, providing better findings and getting the job done faster
- Leave no stone unturned by incorporating memory forensics into your investigations
- Triage, preserve, configure and examine new sources of evidence that only exist in the Cloud and incorporate these new sources into your investigations
- Understand the capabilities of malware to derive threat intelligence, respond to information security incidents, and fortify defenses
- Identify, extract, prioritize, and leverage cyber threat intelligence from advanced persistent threat (APT) intrusions
- Recognize that a properly trained incident responder could be the only defense an organization has during a compromise
- Properly identify, collect, preserve, and respond to data from a wide range of storage devices and repositories, ensuring that the integrity of the evidence is beyond reproach

“This training is invaluable to a practitioner! The tools and knowledge that you gain from it is just outstanding!”

—James Tayler, Context Information Security

Digital Forensics & Incident Response (DFIR) and Threat Hunting Job Roles:

- Threat Hunter
- Digital Forensics Analyst
- Malware Analyst
- Incident Responder
- Media Exploitation Analyst
- Threat Intelligence Analyst
- Law Enforcement Professional



Discover the **Best College** in Cybersecurity

SANS
Technology
Institute



Start

Prepare to launch your cybersecurity career.
Undergraduate Certificate and Bachelor's Degrees



Advance

Strengthen job-specific skills.
Graduate Certificate Programs



Lead

Take your career to the highest levels.
M.S. in Information Security Engineering

Learn how you might be able to bring this course into a **SANS.edu** program.

Email **info@sans.edu**
Call **301.241.7665**



SANS.edu